Governix

Input Validation Reference

Every input the Governix API accepts, the rules it checks, and who may send it: module by module and role by role.

Endpoints	Modules	Field rules	Server-side rules	Need an authenticator code	Rate-limited
144	19	419	205	16	7

Generated 2026-11-05 directly from the source code (routes, request schemas, permission checks and service rules), so it matches the running application at that date.

1. How to read this document

- **Section 2** lists the rules that apply everywhere: sign-in, sessions, passwords, authenticator codes, rate limits.
- **Section 3** lists the roles, their permissions and who may create whom.
- **Section 4** is role-wise: for each role, every endpoint it may call.
- **Section 5** is module-wise: each endpoint with the roles allowed, then every input field with its type, whether it is required and its rules, then the module's server-side rules (checks made after the input format is accepted, with the exact message the user sees).
- Field rules come from the request schemas. A field marked **Required** must be sent; an optional field that is left out keeps its default (or, on an update, stays as it is). *a.b* is field b inside object a.
- **Code needed**: the request must carry a fresh 6-digit code from the person's authenticator app (see 2.4).

What the user gets back when input is wrong

Every error has the same shape: error.code is the HTTP status, error.reason a stable identifier, error.message the text shown to the person. A 422 for a malformed field also lists each field and what is wrong with it (never the value that was sent).

Status	Meaning	Typical reason
422	Input invalid: a field breaks a rule in this document, or a server-side rule refuses it.	VALIDATION_ERROR, plus specific reasons such as INVALID_MFA_CODE
401	Not signed in, session expired, wrong password or code at sign-in.	UNAUTHENTICATED, INVALID_CREDENTIALS, TOKEN_EXPIRED, MFA_CHALLENGE_EXPIRED
403	Signed in but not allowed: missing permission, CSRF check failed, or authenticator code needed / wrong.	PERMISSION_DENIED, CSRF_FAILED, STEP_UP_REQUIRED, STEP_UP_INVALID
404	Not found, or outside the person's scope (another bank or branch is never revealed).	NOT_FOUND
409	Conflicts with the current state (already exists, already sent, confirmation needed).	EMAIL_TAKEN, ALREADY_CONFIRMED, DELETE_CONFIRMATION_REQUIRED
413	File or body too large.	PAYLOAD_TOO_LARGE
429	Too many requests in a short time.	RATE_LIMITED

2. Rules that apply everywhere

2.1 Sign-in and sessions

- Sessions live in HttpOnly cookies; tokens are never in a response body. Access token: 15 minutes, renewed automatically; refresh token: 7 days.
- Every change request made with the session cookie (POST, PUT, PATCH, DELETE) must carry the X-CSRF-Token header matching the session. Missing or wrong -> 403 CSRF_FAILED. Scripts using Authorization: Bearer need no CSRF header.
- Deactivated accounts, deleted accounts and accounts of a suspended organization cannot sign in.
- Temporary account lock after repeated failed sign-ins: currently switched off (failed attempts are still counted and recorded in the audit log).

2.2 Passwords

Every new password (an admin setting one, changing your own, a reset link, a bank's first admin, the Master Admin from the command line) must meet all of these. Existing passwords keep working at sign-in; the rules apply when a password is set. The page shows a checklist that turns green as each rule is met, and the server checks again.

Rule	Example that fails
12 to 128 characters	Sh0rt#pass
At least one capital letter (A-Z)	strong#pass2026
At least one small letter (a-z)	STRONG#PASS2026
At least one digit (0-9)	Strong#Password
At least one symbol such as @ # $ % & * !	StrongPass2026x
No space at the start or end	Strong#Pass2026 with a space before or after it
No character 4 or more times in a row	Strong#Paaaass26
Must not contain the person's name (any part of 3+ letters) or the part of their email before @	Riya#Strong-2026 for Riya Sharma

Example that passes: Strong#Pass2026. Passwords generated by Governix (temporary passwords) always meet the policy: 16 characters, no look-alike characters such as 0/O or 1/l.

- The new password must differ from the current one.
- Changing your password needs the current password and signs you out on every device.
- Password reset links are single-use and expire; asking for one always gives the same answer, whether or not the email is registered.

2.3 Two-step sign-in (authenticator app)

- Optional for everyone. Codes are 6 digits from Google Authenticator or a similar app; a code is accepted once, within about 30 seconds either side of now.
- After the password, the code step stays open 5 minutes. A backup code (12 letters and digits, e.g. k7mq-x3vp-9t2n) may replace the app code at sign-in only, once each.
- Turning it off needs the password and a current app code (never a backup code). Lost phone: an admin who manages the account resets it.
- Set up, turned off, reset, or a backup code used: the person and their managers get a security alert.

2.4 Important actions need a fresh authenticator code

Sent in the X-Authenticator-Code header (the web page asks for it). Without two-step sign-in the action is refused (STEP_UP_SETUP_REQUIRED); a missing, wrong or already used code gives STEP_UP_REQUIRED, STEP_UP_INVALID or STEP_UP_CODE_USED. One code approves one action; backup codes are not accepted.

Action	Endpoint	When	Who may do it
Update organization	`PATCH /organizations/{organization_id}`	only when the status changes (suspend / reactivate)	Master Admin
Soft-delete the organisation and everything in it.	`DELETE /organizations/{organization_id}`	only the real deletion (confirm=true), not the preview	Master Admin
Deploy	`POST /nginx/{organization_id}/deploy`	always	Master Admin
Disable	`POST /nginx/{organization_id}/disable`	always	Master Admin
Soft-delete the branch and everything in it.	`DELETE /branches/{branch_id}`	only the real deletion (confirm=true), not the preview	Org Admin
Soft-delete the department and its users.	`DELETE /departments/{department_id}`	only the real deletion (confirm=true), not the preview	Org Admin, Branch Manager
Create user	`POST /users`	always	Master Admin, Org Admin, Branch Manager
Update user	`PATCH /users/{user_id}`	only when email, role, is_active, organization, branch or department changes	Master Admin, Org Admin, Branch Manager
Delete user	`DELETE /users/{user_id}`	always	Master Admin, Org Admin, Branch Manager
Reset password	`POST /users/{user_id}/reset-password`	always	Master Admin, Org Admin, Branch Manager
Turn off a user's two-step sign-in (lost phone).	`POST /users/{user_id}/reset-mfa`	always	Master Admin, Org Admin, Branch Manager
Delete a document permanently, with its version, chunks and stored file.	`DELETE /documents/{document_id}`	always	Org Admin, Branch Manager
Withdraw version	`POST /policies/{policy_id}/versions/{version_id}/withdraw`	always	Org Admin, Branch Manager
Activate an archived version: it rejoins the effective-date timeline.	`POST /policies/{policy_id}/versions/{version_id}/restore`	always	Org Admin, Branch Manager
Delete a policy permanently, with every version, document and stored file.	`DELETE /policies/{policy_id}`	always	Org Admin, Branch Manager
Put someone on support duty, with their skills, capacity and availability.	`POST /support/staff`	always	Master Admin, Org Admin, Branch Manager

2.5 Input formats used across modules

Text fields are cleaned before their length is checked: spaces at both ends are removed, and in one-line fields runs of spaces become one, so a value of only spaces never counts. Each field in section 5 lists which of these it follows.

Format	Used for	Rules	Refused, for example
Person name	Full names of users, admins and support agents	Letters (any language), spaces, apostrophes, hyphens and dots; at least 2 letters	Agent 007, J
Name / title	Banks, branches, departments, categories, policies, documents, ticket subjects, conversation titles	One line; at least one letter or digit; no < or >	<script>, ---
Line	Issuer, owner, policy and document numbers, version labels, file names, search	One line, no control characters, not blank	a value with a line break

Format	Used for	Rules	Refused, for example
Text	Descriptions, notes, messages, reasons, AI questions, addresses	Line breaks allowed; no control characters; not blank (optional ones: blank means not given)	only spaces
Phone	User, support agent and bank contact phones	Digits, spaces and + ( ) - . only; 7 to 15 digits; + only at the start; at most 30 characters	12345, call me, 91+98765
Website	Bank website	Starts with http:// or https://; no spaces	www.bank.com
Tag	Support skills, category keywords	One item of 1-50 characters; no commas; no < or >	sql, python
Email	Every email field	A valid email address (checked by the email standard)	name@, @bank.com

2.6 Rate limits

Endpoint	Purpose	Limit
`POST /auth/mfa/verify`	The code step of a two-step sign-in: a code from the authenticator app, or a backup code.	30 requests per 5 minutes per client address
`POST /auth/mfa/enable`	Confirm the setup with a code from the app.	10 requests per 5 minutes per account
`POST /auth/mfa/disable`	Turn two-step sign-in off.	10 requests per 5 minutes per account
`POST /auth/mfa/recovery-codes`	New backup codes (the old ones stop working).	10 requests per 5 minutes per account
`POST /auth/forgot-password`	Email a single-use reset link.	3 requests per 15 minutes per email; 10 requests per 15 minutes per client address
`POST /ai/ask`	Answer from authorised, effective evidence only, with verified citations.	20 questions per 60 s per user
`POST /ai/ask/stream`	The same answer as POST /ai/ask, as server-sent events.	20 questions per 60 s per user

3. Roles and permissions

Role	Scope	May create / manage accounts of
Master Admin	Runs the platform: organizations, their Org Admins, Support Agents, bank portals; reads every audit log. Has no access to any bank's documents, policies or AI Assistant.	Org Admin, Support Agent
Org Admin	One bank: branches, departments, Branch Managers, categories, policies and documents, assignments, Head Office support staff. Does not use the AI Assistant.	Branch Manager
Branch Manager	One branch: its Users, departments, branch policies and documents, assignments, Branch Support staff. Uses the AI Assistant.	User
User	Reads the policies assigned to them, asks the AI Assistant, raises support tickets.	nobody
Support Agent	Governix Technical Support: works the Technical Support queue only.	nobody

Beyond the permission, every action is limited to the person's own scope: an Org Admin to their bank, a Branch Manager to their branch, a User to what is assigned to them. Something outside the scope answers 404, as if it did not exist.

Permission matrix

Permission	Master Admin	Org Admin	Branch Manager	User	Support Agent
`organizations:manage`	**yes**	-	-	-	-
`system:monitor`	**yes**	-	-	-	-
`branches:manage`	-	**yes**	-	-	-
`departments:manage`	-	**yes**	**yes**	-	-
`users:manage`	**yes**	**yes**	**yes**	-	-
`categories:manage`	-	**yes**	-	-	-
`documents:read`	-	**yes**	**yes**	**yes**	-
`documents:upload`	-	**yes**	**yes**	-	-
`documents:manage`	-	**yes**	**yes**	-	-
`policies:read`	-	**yes**	**yes**	**yes**	-
`policies:manage`	-	**yes**	**yes**	-	-
`policies:assign`	-	**yes**	**yes**	-	-
`search`	-	**yes**	**yes**	**yes**	-
`ai:query`	-	-	**yes**	**yes**	-
`audit:read`	**yes**	**yes**	-	-	-
`support`	**yes**	**yes**	**yes**	**yes**	**yes**
`support:staff`	**yes**	**yes**	**yes**	-	-

4. Role-wise: what each role may call

Endpoints whose permission the role holds (and public ones). Scope rules still apply inside each endpoint; the inputs and rules of each endpoint are in section 5.

4.1 Master Admin - 73 endpoints

Module	Method	Endpoint	Purpose	Code needed
Sign-in & Account	POST	/auth/login	Signs in, or, for an account with two-step sign-in, answers `mfa_required` and opens the code step: send the code to /auth/mfa/verify.	
Sign-in & Account	POST	/auth/mfa/verify	The code step of a two-step sign-in: a code from the authenticator app, or a backup code.	
Sign-in & Account	GET	/auth/mfa	Mfa status	
Sign-in & Account	POST	/auth/mfa/setup	Start setting up an authenticator app: scan the QR code (`otpauth_uri`) or type `secret`, then confirm with /auth/mfa/enable.	
Sign-in & Account	POST	/auth/mfa/enable	Confirm the setup with a code from the app.	
Sign-in & Account	POST	/auth/mfa/disable	Turn two-step sign-in off.	
Sign-in & Account	POST	/auth/mfa/recovery-codes	New backup codes (the old ones stop working).	
Sign-in & Account	POST	/auth/refresh	Refresh	
Sign-in & Account	POST	/auth/logout	Logout	
Sign-in & Account	GET	/auth/me	Me	
Sign-in & Account	POST	/auth/change-password	Change password	
Sign-in & Account	POST	/auth/forgot-password	Email a single-use reset link.	
Sign-in & Account	POST	/auth/reset-password	Set a new password from a reset link.	
Users	POST	/users	Create user	Yes
Users	GET	/users	List users	
Users	GET	/users/stats	User stats	
Users	GET	/users/{user_id}	Get user	
Users	PATCH	/users/{user_id}	Update user	Yes: only when email, role, is_active, organization, branch or department changes
Users	DELETE	/users/{user_id}	Delete user	Yes
Users	POST	/users/{user_id}/reset-password	Reset password	Yes
Users	POST	/users/{user_id}/reset-mfa	Turn off a user's two-step sign-in (lost phone).	Yes
Organizations	POST	/organizations	Create an organisation (with branding) and, optionally, its first admin.	
Organizations	GET	/organizations	List organizations	
Organizations	GET	/organizations/options	For the create and edit forms: the port range, the ports already in use, and the brand fonts.	
Organizations	GET	/organizations/me	The caller's organisation: name, branding and contact details.	
Organizations	GET	/organizations/{organization_id}	Get organization	

Module	Method	Endpoint	Purpose	Code needed
Organizations	PATCH	/organizations/{organization_id}	Update organization	Yes: only when the status changes (suspend / reactivate)
Organizations	GET	/organizations/{organization_id}/delete-preview	What deleting the organisation would also delete: its branches, departments, users and policies.	
Organizations	DELETE	/organizations/{organization_id}	Soft-delete the organisation and everything in it.	Yes: only the real deletion (confirm=true), not the preview
Organizations	POST	/organizations/{organization_id}/logo	Upload logo	
Organizations	GET	/organizations/{organization_id}/logo	Get logo	
Branches	GET	/branches	List branches	
Branches	GET	/branches/{branch_id}	Get branch	
Departments	GET	/departments	List departments	
Departments	GET	/departments/{department_id}	Get department	
Categories	GET	/categories	List categories	
Support Center	GET	/support/staff	The support staff the caller manages: Master Admin, platform; Organization Admin, their bank's Head Office and branches; Branch Manager, their branch.	
Support Center	GET	/support/staff/candidates	Accounts the caller may put on duty at that level (not on duty already).	
Support Center	POST	/support/staff	Put someone on support duty, with their skills, capacity and availability.	Yes
Support Center	GET	/support/staff/me	The caller's own support duty, or null.	
Support Center	PATCH	/support/staff/me	Staff set their own availability.	
Support Center	PATCH	/support/staff/{staff_id}	Change role (agent/lead), skills, capacity, availability, active, or the banks a platform member serves.	
Support Center	DELETE	/support/staff/{staff_id}	Take someone off support duty (their account stays).	
Support Center	POST	/support/staff/{staff_id}/reassign	Move this person's open tickets to others by workload, each one recorded and notified.	
Support Center	GET	/support/categories	The ticket categories of the caller's organization (its own, or the defaults).	
Support Center	POST	/support/tickets	Raise a ticket (Users, Branch Managers, Organization Admins).	
Support Center	POST	/support/tickets/{ticket_id}/confirm	The creator confirms the destination team (the recommended one, or another).	
Support Center	GET	/support/tickets	box: mine (raised by me), queue (the queues I work or manage), assigned (to me), unassigned (in my queues), all (everything I may see, including what I oversee).	
Support Center	GET	/support/tickets/dashboard	Counts for one box: by status, team, priority, level and assignee; overdue and unassigned.	
Support Center	GET	/support/tickets/{ticket_id}	The ticket with its timeline (replies, the internal notes the caller may read, status changes, forwards, assignments), attachments and the actions the caller may take.	
Support Center	POST	/support/tickets/{ticket_id}/messages	A reply (visible to the creator), or with internal=true a note for the handling team only.	
Support Center	POST	/support/tickets/{ticket_id}/status	Staff: open -> in_progress / waiting_for_user / waiting_for_team -> resolved (with a note), resolved -> in_progress.	
Support Center	POST	/support/tickets/{ticket_id}/priority	The handling team changes the priority; the SLA due times follow it.	

Module	Method	Endpoint	Purpose	Code needed
Support Center	POST	/support/tickets/{ticket_id}/assign	Take the ticket (your own id: a member of its queue), or assign / reassign / unassign it (the queue's manager or lead).	
Support Center	GET	/support/tickets/{ticket_id}/assignees	The staff of the ticket's queue (or of a forwarding destination) with their availability and workload.	
Support Center	POST	/support/tickets/{ticket_id}/forward	Forward to Branch Support, Head Office Support or Technical Support (or `escalate`: one level up), with a reason and confirmed=true.	
Support Center	POST	/support/tickets/{ticket_id}/cancel	The creator withdraws a draft or open ticket; a queue manager cancels one with a note.	
Support Center	POST	/support/tickets/{ticket_id}/attachments	PDF, image, text, CSV, Word or Excel, up to 10 MB.	
Support Center	GET	/support/tickets/{ticket_id}/attachments/{attachment_id}	Download attachment	
Support Center	GET	/support/categories/manage	Organization Admin: every category, active or not.	
Support Center	POST	/support/categories	Organization Admin: add a category.	
Support Center	PATCH	/support/categories/{category_id}	Organization Admin: rename, re-route, reorder or deactivate a category (the defaults too).	
Notifications	GET	/notifications	My notifications	
Notifications	POST	/notifications/read	Mark read	
Audit Log	GET	/audit-events	List audit events	
Audit Log	GET	/audit-events/actions	List audit actions	
Dashboard	GET	/dashboard/ai-usage	AI provider usage (tokens, estimated or exact cost) and the credit left, if one is configured.	
Bank Portals (nginx)	GET	/nginx	Overview	
Bank Portals (nginx)	GET	/nginx/{organization_id}	Detail	
Bank Portals (nginx)	POST	/nginx/{organization_id}/deploy	Deploy	Yes
Bank Portals (nginx)	POST	/nginx/{organization_id}/disable	Disable	Yes
Health	GET	/health	Health	
Health	GET	/db-health	Db health	

4.2 Org Admin - 125 endpoints

Module	Method	Endpoint	Purpose	Code needed
Sign-in & Account	POST	/auth/login	Signs in, or, for an account with two-step sign-in, answers `mfa_required` and opens the code step: send the code to /auth/mfa/verify.	
Sign-in & Account	POST	/auth/mfa/verify	The code step of a two-step sign-in: a code from the authenticator app, or a backup code.	
Sign-in & Account	GET	/auth/mfa	Mfa status	
Sign-in & Account	POST	/auth/mfa/setup	Start setting up an authenticator app: scan the QR code (`otpauth_uri`) or type `secret`, then confirm with /auth/mfa/enable.	
Sign-in & Account	POST	/auth/mfa/enable	Confirm the setup with a code from the app.	
Sign-in & Account	POST	/auth/mfa/disable	Turn two-step sign-in off.	
Sign-in & Account	POST	/auth/mfa/recovery-codes	New backup codes (the old ones stop working).	
Sign-in & Account	POST	/auth/refresh	Refresh	
Sign-in & Account	POST	/auth/logout	Logout	
Sign-in & Account	GET	/auth/me	Me	
Sign-in & Account	POST	/auth/change-password	Change password	
Sign-in & Account	POST	/auth/forgot-password	Email a single-use reset link.	
Sign-in & Account	POST	/auth/reset-password	Set a new password from a reset link.	
Users	POST	/users	Create user	Yes
Users	GET	/users	List users	
Users	GET	/users/stats	User stats	
Users	GET	/users/{user_id}	Get user	
Users	PATCH	/users/{user_id}	Update user	Yes: only when email, role, is_active, organization, branch or department changes
Users	DELETE	/users/{user_id}	Delete user	Yes
Users	POST	/users/{user_id}/reset-password	Reset password	Yes
Users	POST	/users/{user_id}/reset-mfa	Turn off a user's two-step sign-in (lost phone).	Yes
Organizations	GET	/organizations/options	For the create and edit forms: the port range, the ports already in use, and the brand fonts.	
Organizations	GET	/organizations/me	The caller's organisation: name, branding and contact details.	
Organizations	GET	/organizations/{organization_id}/logo	Get logo	
Branches	POST	/branches	Create branch	
Branches	GET	/branches	List branches	
Branches	GET	/branches/{branch_id}	Get branch	
Branches	PATCH	/branches/{branch_id}	Update branch	
Branches	GET	/branches/{branch_id}/delete-preview	What deleting the branch would also delete: its departments, users and policies.	
Branches	DELETE	/branches/{branch_id}	Soft-delete the branch and everything in it.	Yes: only the real deletion (confirm=true), not the preview

Module	Method	Endpoint	Purpose	Code needed
Departments	POST	/departments	Create department	
Departments	GET	/departments	List departments	
Departments	GET	/departments/{department_id}	Get department	
Departments	PATCH	/departments/{department_id}	Update department	
Departments	GET	/departments/{department_id}/delete-preview	What deleting the department would also delete: its users and policies.	
Departments	DELETE	/departments/{department_id}	Soft-delete the department and its users.	Yes: only the real deletion (confirm=true), not the preview
Categories	GET	/categories	List categories	
Categories	GET	/categories/overview	Every category with its policy count and last activity (over what the caller can see).	
Categories	POST	/categories	Create category	
Categories	GET	/categories/{category_id}	Get category	
Categories	PATCH	/categories/{category_id}	Update category	
Categories	GET	/categories/{category_id}/documents	Policies in the category with every version and the file behind it.	
Categories	GET	/categories/{category_id}/pending	Files uploaded into the category that are still processing or waiting for review.	
Policies & Versions	GET	/policies	List policies	
Policies & Versions	POST	/policies	Create a policy by hand (global or branch); upload its documents into it afterwards.	
Policies & Versions	GET	/policies/{policy_id}	Get policy	
Policies & Versions	PATCH	/policies/{policy_id}	Update policy	
Policies & Versions	GET	/policies/{policy_id}/versions	Every version, newest first, with the file behind it and who uploaded it.	
Policies & Versions	GET	/policies/{policy_id}/versions/{version_id}	Get version	
Policies & Versions	GET	/policies/{policy_id}/compare	Deterministic side-by-side comparison; original text of both versions is included.	
Policies & Versions	POST	/policies/{policy_id}/versions/{version_id}/withdraw	Withdraw version	Yes
Policies & Versions	POST	/policies/{policy_id}/versions/{version_id}/restore	Activate an archived version: it rejoins the effective-date timeline.	Yes
Policies & Versions	PUT	/policies/{policy_id}/versions/order	Drag-and-drop version order, newest first: it becomes the timeline and the first is the latest.	
Policies & Versions	POST	/policies/{policy_id}/versions/{version_id}/move	Move a document to another policy's version group (requires confirm=true).	
Policies & Versions	GET	/policies/{policy_id}/versions/{version_id}/summary	AI summary of the version (labelled AI-generated) with dates and changes from the database.	
Policies & Versions	POST	/policies/{policy_id}/versions/{version_id}/summary	Regenerate summary	
Policies & Versions	DELETE	/policies/{policy_id}	Delete a policy permanently, with every version, document and stored file.	Yes
Policies & Versions	POST	/policies/{policy_id}/move	Arrange a document within its category.	
Policies & Versions	POST	/documents/{document_id}/relationships	Add relationship	
Documents	POST	/documents	Upload document	
Documents	GET	/documents/upload-limits	What the server accepts, so files can be checked before they are sent.	
Documents	POST	/documents/duplicates	Which files (SHA-256 computed in the browser) already exist, before anything is uploaded.	

Module	Method	Endpoint	Purpose	Code needed
Documents	GET	/documents	List documents	
Documents	GET	/documents/{document_id}	Get document	
Documents	GET	/documents/{document_id}/progress	Get progress	
Documents	GET	/documents/{document_id}/file	Download file	
Documents	PATCH	/documents/{document_id}	Update document	
Documents	POST	/documents/{document_id}/archive	Archive document	
Documents	DELETE	/documents/{document_id}	Delete a document permanently, with its version, chunks and stored file.	Yes
Documents	POST	/documents/{document_id}/retry	Retry document	
Documents	GET	/documents/{document_id}/pages/{page_number}/image	PNG of one page; `highlight_chunk` marks a cited passage on the page.	
Documents	GET	/documents/{document_id}/pages/{page_number}	Get page text	
Documents	GET	/documents/{document_id}/outline	Get outline	
Documents	GET	/documents/{document_id}/chunks/{chunk_id}	Get chunk	
Document Ingestion	GET	/documents/{document_id}/analysis	Get analysis	
Document Ingestion	POST	/documents/{document_id}/confirm	Accept, adjust or reject the system's suggestion for an uploaded document.	
Bulk Uploads	POST	/uploads/suggestions	Read a file's opening pages while uploads are being arranged: the policy name the document states, its category, and an existing policy it most likely is a version of.	
Bulk Uploads	POST	/uploads/batches	Plan a bulk upload: policies (new or existing) and each one's files in version order, oldest first.	
Bulk Uploads	POST	/uploads/batches/{batch_id}/items/{item_id}/file	Send one planned file.	
Bulk Uploads	POST	/uploads/batches/{batch_id}/items/{item_id}/cancel	Cancel a planned file that has not been sent yet.	
Bulk Uploads	POST	/uploads/batches/{batch_id}/start	All files sent: stop waiting for missing ones and confirm every group whose files are analysed.	
Bulk Uploads	GET	/uploads/batches	List batches	
Bulk Uploads	GET	/uploads/batches/{batch_id}	Get batch	
Policy Assignments	GET	/assignments/users	The caller's Users and the policies assigned to each (a Branch Manager: their branch).	
Policy Assignments	GET	/policies/{policy_id}/assignments	Users this policy is assigned to (within the caller's branch); with history on request.	
Policy Assignments	POST	/policies/{policy_id}/assignments	Assign users	
Policy Assignments	DELETE	/policies/{policy_id}/assignments/{user_id}	Unassign user	
Policy Assignments	GET	/policies/{policy_id}/assignable-users	Assignable users	
Policy Assignments	GET	/users/{user_id}/assignments	User assignments	
Policy Assignments	POST	/users/{user_id}/assignments	Assign policies	
Search	POST	/search	Hybrid search over authorised, effective content (passages carry full provenance).	
Support Center	GET	/support/staff	The support staff the caller manages: Master Admin, platform; Organization Admin, their bank's Head Office and branches; Branch Manager, their branch.	
Support Center	GET	/support/staff/candidates	Accounts the caller may put on duty at that level (not on duty already).	

Module	Method	Endpoint	Purpose	Code needed
Support Center	POST	/support/staff	Put someone on support duty, with their skills, capacity and availability.	Yes
Support Center	GET	/support/staff/me	The caller's own support duty, or null.	
Support Center	PATCH	/support/staff/me	Staff set their own availability.	
Support Center	PATCH	/support/staff/{staff_id}	Change role (agent/lead), skills, capacity, availability, active, or the banks a platform member serves.	
Support Center	DELETE	/support/staff/{staff_id}	Take someone off support duty (their account stays).	
Support Center	POST	/support/staff/{staff_id}/reassign	Move this person's open tickets to others by workload, each one recorded and notified.	
Support Center	GET	/support/categories	The ticket categories of the caller's organization (its own, or the defaults).	
Support Center	POST	/support/tickets	Raise a ticket (Users, Branch Managers, Organization Admins).	
Support Center	POST	/support/tickets/{ticket_id}/confirm	The creator confirms the destination team (the recommended one, or another).	
Support Center	GET	/support/tickets	box: mine (raised by me), queue (the queues I work or manage), assigned (to me), unassigned (in my queues), all (everything I may see, including what I oversee).	
Support Center	GET	/support/tickets/dashboard	Counts for one box: by status, team, priority, level and assignee; overdue and unassigned.	
Support Center	GET	/support/tickets/{ticket_id}	The ticket with its timeline (replies, the internal notes the caller may read, status changes, forwards, assignments), attachments and the actions the caller may take.	
Support Center	POST	/support/tickets/{ticket_id}/messages	A reply (visible to the creator), or with internal=true a note for the handling team only.	
Support Center	POST	/support/tickets/{ticket_id}/status	Staff: open -> in_progress / waiting_for_user / waiting_for_team -> resolved (with a note), resolved -> in_progress.	
Support Center	POST	/support/tickets/{ticket_id}/priority	The handling team changes the priority; the SLA due times follow it.	
Support Center	POST	/support/tickets/{ticket_id}/assign	Take the ticket (your own id: a member of its queue), or assign / reassign / unassign it (the queue's manager or lead).	
Support Center	GET	/support/tickets/{ticket_id}/assignees	The staff of the ticket's queue (or of a forwarding destination) with their availability and workload.	
Support Center	POST	/support/tickets/{ticket_id}/forward	Forward to Branch Support, Head Office Support or Technical Support (or `escalate`: one level up), with a reason and confirmed=true.	
Support Center	POST	/support/tickets/{ticket_id}/cancel	The creator withdraws a draft or open ticket; a queue manager cancels one with a note.	
Support Center	POST	/support/tickets/{ticket_id}/attachments	PDF, image, text, CSV, Word or Excel, up to 10 MB.	
Support Center	GET	/support/tickets/{ticket_id}/attachments/{attachment_id}	Download attachment	
Support Center	GET	/support/categories/manage	Organization Admin: every category, active or not.	
Support Center	POST	/support/categories	Organization Admin: add a category.	
Support Center	PATCH	/support/categories/{category_id}	Organization Admin: rename, re-route, reorder or deactivate a category (the defaults too).	
Notifications	GET	/notifications	My notifications	
Notifications	POST	/notifications/read	Mark read	

Module	Method	Endpoint	Purpose	Code needed
Audit Log	GET	/audit-events	List audit events	
Audit Log	GET	/audit-events/actions	List audit actions	
Dashboard	GET	/dashboard	Dashboard	
Dashboard	GET	/dashboard/ai-usage	AI provider usage (tokens, estimated or exact cost) and the credit left, if one is configured.	
Health	GET	/health	Health	
Health	GET	/db-health	Db health	

4.3 Branch Manager - 125 endpoints

Module	Method	Endpoint	Purpose	Code needed
Sign-in & Account	POST	/auth/login	Signs in, or, for an account with two-step sign-in, answers `mfa_required` and opens the code step: send the code to /auth/mfa/verify.	
Sign-in & Account	POST	/auth/mfa/verify	The code step of a two-step sign-in: a code from the authenticator app, or a backup code.	
Sign-in & Account	GET	/auth/mfa	Mfa status	
Sign-in & Account	POST	/auth/mfa/setup	Start setting up an authenticator app: scan the QR code (`otpauth_uri`) or type `secret`, then confirm with /auth/mfa/enable.	
Sign-in & Account	POST	/auth/mfa/enable	Confirm the setup with a code from the app.	
Sign-in & Account	POST	/auth/mfa/disable	Turn two-step sign-in off.	
Sign-in & Account	POST	/auth/mfa/recovery-codes	New backup codes (the old ones stop working).	
Sign-in & Account	POST	/auth/refresh	Refresh	
Sign-in & Account	POST	/auth/logout	Logout	
Sign-in & Account	GET	/auth/me	Me	
Sign-in & Account	POST	/auth/change-password	Change password	
Sign-in & Account	POST	/auth/forgot-password	Email a single-use reset link.	
Sign-in & Account	POST	/auth/reset-password	Set a new password from a reset link.	
Users	POST	/users	Create user	Yes
Users	GET	/users	List users	
Users	GET	/users/stats	User stats	
Users	GET	/users/{user_id}	Get user	
Users	PATCH	/users/{user_id}	Update user	Yes: only when email, role, is_active, organization, branch or department changes
Users	DELETE	/users/{user_id}	Delete user	Yes
Users	POST	/users/{user_id}/reset-password	Reset password	Yes
Users	POST	/users/{user_id}/reset-mfa	Turn off a user's two-step sign-in (lost phone).	Yes
Organizations	GET	/organizations/options	For the create and edit forms: the port range, the ports already in use, and the brand fonts.	
Organizations	GET	/organizations/me	The caller's organisation: name, branding and contact details.	
Organizations	GET	/organizations/{organization_id}/logo	Get logo	
Branches	GET	/branches	List branches	
Branches	GET	/branches/{branch_id}	Get branch	
Departments	POST	/departments	Create department	
Departments	GET	/departments	List departments	
Departments	GET	/departments/{department_id}	Get department	
Departments	PATCH	/departments/{department_id}	Update department	
Departments	GET	/departments/{department_id}/delete-preview	What deleting the department would also delete: its users and policies.	

Module	Method	Endpoint	Purpose	Code needed
Departments	DELETE	/departments/{department_id}	Soft-delete the department and its users.	Yes: only the real deletion (confirm=true), not the preview
Categories	GET	/categories	List categories	
Categories	GET	/categories/overview	Every category with its policy count and last activity (over what the caller can see).	
Categories	GET	/categories/{category_id}	Get category	
Categories	GET	/categories/{category_id}/documents	Policies in the category with every version and the file behind it.	
Categories	GET	/categories/{category_id}/pending	Files uploaded into the category that are still processing or waiting for review.	
Policies & Versions	GET	/policies	List policies	
Policies & Versions	POST	/policies	Create a policy by hand (global or branch); upload its documents into it afterwards.	
Policies & Versions	GET	/policies/{policy_id}	Get policy	
Policies & Versions	PATCH	/policies/{policy_id}	Update policy	
Policies & Versions	GET	/policies/{policy_id}/versions	Every version, newest first, with the file behind it and who uploaded it.	
Policies & Versions	GET	/policies/{policy_id}/versions/{version_id}	Get version	
Policies & Versions	GET	/policies/{policy_id}/compare	Deterministic side-by-side comparison; original text of both versions is included.	
Policies & Versions	POST	/policies/{policy_id}/versions/{version_id}/withdraw	Withdraw version	Yes
Policies & Versions	POST	/policies/{policy_id}/versions/{version_id}/restore	Activate an archived version: it rejoins the effective-date timeline.	Yes
Policies & Versions	PUT	/policies/{policy_id}/versions/order	Drag-and-drop version order, newest first: it becomes the timeline and the first is the latest.	
Policies & Versions	POST	/policies/{policy_id}/versions/{version_id}/move	Move a document to another policy's version group (requires confirm=true).	
Policies & Versions	GET	/policies/{policy_id}/versions/{version_id}/summary	AI summary of the version (labelled AI-generated) with dates and changes from the database.	
Policies & Versions	POST	/policies/{policy_id}/versions/{version_id}/summary	Regenerate summary	
Policies & Versions	DELETE	/policies/{policy_id}	Delete a policy permanently, with every version, document and stored file.	Yes
Policies & Versions	POST	/policies/{policy_id}/move	Arrange a document within its category.	
Policies & Versions	POST	/documents/{document_id}/relationships	Add relationship	
Documents	POST	/documents	Upload document	
Documents	GET	/documents/upload-limits	What the server accepts, so files can be checked before they are sent.	
Documents	POST	/documents/duplicates	Which files (SHA-256 computed in the browser) already exist, before anything is uploaded.	
Documents	GET	/documents	List documents	
Documents	GET	/documents/{document_id}	Get document	
Documents	GET	/documents/{document_id}/progress	Get progress	
Documents	GET	/documents/{document_id}/file	Download file	
Documents	PATCH	/documents/{document_id}	Update document	
Documents	POST	/documents/{document_id}/archive	Archive document	
Documents	DELETE	/documents/{document_id}	Delete a document permanently, with its version, chunks and stored file.	Yes

Module	Method	Endpoint	Purpose	Code needed
Documents	POST	/documents/{document_id}/retry	Retry document	
Documents	GET	/documents/{document_id}/pages/{page_number}/image	PNG of one page; `highlight_chunk` marks a cited passage on the page.	
Documents	GET	/documents/{document_id}/pages/{page_number}	Get page text	
Documents	GET	/documents/{document_id}/outline	Get outline	
Documents	GET	/documents/{document_id}/chunks/{chunk_id}	Get chunk	
Document Ingestion	GET	/documents/{document_id}/analysis	Get analysis	
Document Ingestion	POST	/documents/{document_id}/confirm	Accept, adjust or reject the system's suggestion for an uploaded document.	
Bulk Uploads	POST	/uploads/suggestions	Read a file's opening pages while uploads are being arranged: the policy name the document states, its category, and an existing policy it most likely is a version of.	
Bulk Uploads	POST	/uploads/batches	Plan a bulk upload: policies (new or existing) and each one's files in version order, oldest first.	
Bulk Uploads	POST	/uploads/batches/{batch_id}/items/{item_id}/file	Send one planned file.	
Bulk Uploads	POST	/uploads/batches/{batch_id}/items/{item_id}/cancel	Cancel a planned file that has not been sent yet.	
Bulk Uploads	POST	/uploads/batches/{batch_id}/start	All files sent: stop waiting for missing ones and confirm every group whose files are analysed.	
Bulk Uploads	GET	/uploads/batches	List batches	
Bulk Uploads	GET	/uploads/batches/{batch_id}	Get batch	
Policy Assignments	GET	/assignments/users	The caller's Users and the policies assigned to each (a Branch Manager: their branch).	
Policy Assignments	GET	/policies/{policy_id}/assignments	Users this policy is assigned to (within the caller's branch); with history on request.	
Policy Assignments	POST	/policies/{policy_id}/assignments	Assign users	
Policy Assignments	DELETE	/policies/{policy_id}/assignments/{user_id}	Unassign user	
Policy Assignments	GET	/policies/{policy_id}/assignable-users	Assignable users	
Policy Assignments	GET	/users/{user_id}/assignments	User assignments	
Policy Assignments	POST	/users/{user_id}/assignments	Assign policies	
Search	POST	/search	Hybrid search over authorised, effective content (passages carry full provenance).	
AI Assistant	POST	/ai/ask	Answer from authorised, effective evidence only, with verified citations.	
AI Assistant	POST	/ai/ask/stream	The same answer as POST /ai/ask, as server-sent events.	
AI Assistant	GET	/ai/queries	The caller's own recent AI questions (from the audit trail).	
AI Assistant	GET	/ai/conversations	The caller's own conversations, most recent first.	
AI Assistant	GET	/ai/conversations/{conversation_id}	A conversation with every question and the answer it got.	
AI Assistant	PATCH	/ai/conversations/{conversation_id}	Rename conversation	
AI Assistant	DELETE	/ai/conversations/{conversation_id}	Delete conversation	
AI Assistant	DELETE	/ai/conversations	Clear the caller's whole chat history.	
Support Center	GET	/support/staff	The support staff the caller manages: Master Admin, platform; Organization Admin, their bank's Head Office and branches; Branch Manager, their branch.	

Module	Method	Endpoint	Purpose	Code needed
Support Center	GET	/support/staff/candidates	Accounts the caller may put on duty at that level (not on duty already).	
Support Center	POST	/support/staff	Put someone on support duty, with their skills, capacity and availability.	Yes
Support Center	GET	/support/staff/me	The caller's own support duty, or null.	
Support Center	PATCH	/support/staff/me	Staff set their own availability.	
Support Center	PATCH	/support/staff/{staff_id}	Change role (agent/lead), skills, capacity, availability, active, or the banks a platform member serves.	
Support Center	DELETE	/support/staff/{staff_id}	Take someone off support duty (their account stays).	
Support Center	POST	/support/staff/{staff_id}/reassign	Move this person's open tickets to others by workload, each one recorded and notified.	
Support Center	GET	/support/categories	The ticket categories of the caller's organization (its own, or the defaults).	
Support Center	POST	/support/tickets	Raise a ticket (Users, Branch Managers, Organization Admins).	
Support Center	POST	/support/tickets/{ticket_id}/confirm	The creator confirms the destination team (the recommended one, or another).	
Support Center	GET	/support/tickets	box: mine (raised by me), queue (the queues I work or manage), assigned (to me), unassigned (in my queues), all (everything I may see, including what I oversee).	
Support Center	GET	/support/tickets/dashboard	Counts for one box: by status, team, priority, level and assignee; overdue and unassigned.	
Support Center	GET	/support/tickets/{ticket_id}	The ticket with its timeline (replies, the internal notes the caller may read, status changes, forwards, assignments), attachments and the actions the caller may take.	
Support Center	POST	/support/tickets/{ticket_id}/messages	A reply (visible to the creator), or with internal=true a note for the handling team only.	
Support Center	POST	/support/tickets/{ticket_id}/status	Staff: open -> in_progress / waiting_for_user / waiting_for_team -> resolved (with a note), resolved -> in_progress.	
Support Center	POST	/support/tickets/{ticket_id}/priority	The handling team changes the priority; the SLA due times follow it.	
Support Center	POST	/support/tickets/{ticket_id}/assign	Take the ticket (your own id: a member of its queue), or assign / reassign / unassign it (the queue's manager or lead).	
Support Center	GET	/support/tickets/{ticket_id}/assignees	The staff of the ticket's queue (or of a forwarding destination) with their availability and workload.	
Support Center	POST	/support/tickets/{ticket_id}/forward	Forward to Branch Support, Head Office Support or Technical Support (or `escalate`: one level up), with a reason and confirmed=true.	
Support Center	POST	/support/tickets/{ticket_id}/cancel	The creator withdraws a draft or open ticket; a queue manager cancels one with a note.	
Support Center	POST	/support/tickets/{ticket_id}/attachments	PDF, image, text, CSV, Word or Excel, up to 10 MB.	
Support Center	GET	/support/tickets/{ticket_id}/attachments/{attachment_id}	Download attachment	
Support Center	GET	/support/categories/manage	Organization Admin: every category, active or not.	
Support Center	POST	/support/categories	Organization Admin: add a category.	
Support Center	PATCH	/support/categories/{category_id}	Organization Admin: rename, re-route, reorder or deactivate a category (the defaults too).	
Notifications	GET	/notifications	My notifications	

Module	Method	Endpoint	Purpose	Code needed
Notifications	POST	/notifications/read	Mark read	
Dashboard	GET	/dashboard	Dashboard	
Dashboard	GET	/dashboard/ai-usage	AI provider usage (tokens, estimated or exact cost) and the credit left, if one is configured.	
Health	GET	/health	Health	
Health	GET	/db-health	Db health	

4.4 User - 73 endpoints

Module	Method	Endpoint	Purpose	Code needed
Sign-in & Account	POST	/auth/login	Signs in, or, for an account with two-step sign-in, answers `mfa_required` and opens the code step: send the code to /auth/mfa/verify.	
Sign-in & Account	POST	/auth/mfa/verify	The code step of a two-step sign-in: a code from the authenticator app, or a backup code.	
Sign-in & Account	GET	/auth/mfa	Mfa status	
Sign-in & Account	POST	/auth/mfa/setup	Start setting up an authenticator app: scan the QR code (`otpauth_uri`) or type `secret`, then confirm with /auth/mfa/enable.	
Sign-in & Account	POST	/auth/mfa/enable	Confirm the setup with a code from the app.	
Sign-in & Account	POST	/auth/mfa/disable	Turn two-step sign-in off.	
Sign-in & Account	POST	/auth/mfa/recovery-codes	New backup codes (the old ones stop working).	
Sign-in & Account	POST	/auth/refresh	Refresh	
Sign-in & Account	POST	/auth/logout	Logout	
Sign-in & Account	GET	/auth/me	Me	
Sign-in & Account	POST	/auth/change-password	Change password	
Sign-in & Account	POST	/auth/forgot-password	Email a single-use reset link.	
Sign-in & Account	POST	/auth/reset-password	Set a new password from a reset link.	
Users	GET	/users/{user_id}	Get user	
Organizations	GET	/organizations/options	For the create and edit forms: the port range, the ports already in use, and the brand fonts.	
Organizations	GET	/organizations/me	The caller's organisation: name, branding and contact details.	
Organizations	GET	/organizations/{organization_id}/logo	Get logo	
Branches	GET	/branches	List branches	
Branches	GET	/branches/{branch_id}	Get branch	
Departments	GET	/departments	List departments	
Departments	GET	/departments/{department_id}	Get department	
Categories	GET	/categories	List categories	
Categories	GET	/categories/overview	Every category with its policy count and last activity (over what the caller can see).	
Categories	GET	/categories/{category_id}	Get category	
Categories	GET	/categories/{category_id}/documents	Policies in the category with every version and the file behind it.	
Categories	GET	/categories/{category_id}/pending	Files uploaded into the category that are still processing or waiting for review.	
Policies & Versions	GET	/policies	List policies	
Policies & Versions	GET	/policies/{policy_id}	Get policy	
Policies & Versions	GET	/policies/{policy_id}/versions	Every version, newest first, with the file behind it and who uploaded it.	
Policies & Versions	GET	/policies/{policy_id}/versions/{version_id}	Get version	
Policies & Versions	GET	/policies/{policy_id}/compare	Deterministic side-by-side comparison; original text of both versions is included.	

Module	Method	Endpoint	Purpose	Code needed
Policies & Versions	GET	/policies/{policy_id}/versions/{version_id}/summary	AI summary of the version (labelled AI-generated) with dates and changes from the database.	
Documents	GET	/documents	List documents	
Documents	GET	/documents/{document_id}	Get document	
Documents	GET	/documents/{document_id}/progress	Get progress	
Documents	GET	/documents/{document_id}/file	Download file	
Documents	GET	/documents/{document_id}/pages/{page_number}/image	PNG of one page; `highlight_chunk` marks a cited passage on the page.	
Documents	GET	/documents/{document_id}/pages/{page_number}	Get page text	
Documents	GET	/documents/{document_id}/outline	Get outline	
Documents	GET	/documents/{document_id}/chunks/{chunk_id}	Get chunk	
Document Ingestion	GET	/documents/{document_id}/analysis	Get analysis	
Search	POST	/search	Hybrid search over authorised, effective content (passages carry full provenance).	
AI Assistant	POST	/ai/ask	Answer from authorised, effective evidence only, with verified citations.	
AI Assistant	POST	/ai/ask/stream	The same answer as POST /ai/ask, as server-sent events.	
AI Assistant	GET	/ai/queries	The caller's own recent AI questions (from the audit trail).	
AI Assistant	GET	/ai/conversations	The caller's own conversations, most recent first.	
AI Assistant	GET	/ai/conversations/{conversation_id}	A conversation with every question and the answer it got.	
AI Assistant	PATCH	/ai/conversations/{conversation_id}	Rename conversation	
AI Assistant	DELETE	/ai/conversations/{conversation_id}	Delete conversation	
AI Assistant	DELETE	/ai/conversations	Clear the caller's whole chat history.	
Support Center	GET	/support/staff/me	The caller's own support duty, or null.	
Support Center	PATCH	/support/staff/me	Staff set their own availability.	
Support Center	GET	/support/categories	The ticket categories of the caller's organization (its own, or the defaults).	
Support Center	POST	/support/tickets	Raise a ticket (Users, Branch Managers, Organization Admins).	
Support Center	POST	/support/tickets/{ticket_id}/confirm	The creator confirms the destination team (the recommended one, or another).	
Support Center	GET	/support/tickets	box: mine (raised by me), queue (the queues I work or manage), assigned (to me), unassigned (in my queues), all (everything I may see, including what I oversee).	
Support Center	GET	/support/tickets/dashboard	Counts for one box: by status, team, priority, level and assignee; overdue and unassigned.	
Support Center	GET	/support/tickets/{ticket_id}	The ticket with its timeline (replies, the internal notes the caller may read, status changes, forwards, assignments), attachments and the actions the caller may take.	
Support Center	POST	/support/tickets/{ticket_id}/messages	A reply (visible to the creator), or with internal=true a note for the handling team only.	
Support Center	POST	/support/tickets/{ticket_id}/status	Staff: open -> in_progress / waiting_for_user / waiting_for_team -> resolved (with a note), resolved -> in_progress.	
Support Center	POST	/support/tickets/{ticket_id}/priority	The handling team changes the priority; the SLA due times follow it.	

Module	Method	Endpoint	Purpose	Code needed
Support Center	POST	/support/tickets/{ticket_id}/assign	Take the ticket (your own id: a member of its queue), or assign / reassign / unassign it (the queue's manager or lead).	
Support Center	GET	/support/tickets/{ticket_id}/assignees	The staff of the ticket's queue (or of a forwarding destination) with their availability and workload.	
Support Center	POST	/support/tickets/{ticket_id}/forward	Forward to Branch Support, Head Office Support or Technical Support (or `escalate`: one level up), with a reason and confirmed=true.	
Support Center	POST	/support/tickets/{ticket_id}/cancel	The creator withdraws a draft or open ticket; a queue manager cancels one with a note.	
Support Center	POST	/support/tickets/{ticket_id}/attachments	PDF, image, text, CSV, Word or Excel, up to 10 MB.	
Support Center	GET	/support/tickets/{ticket_id}/attachments/{attachment_id}	Download attachment	
Notifications	GET	/notifications	My notifications	
Notifications	POST	/notifications/read	Mark read	
Dashboard	GET	/dashboard	Dashboard	
Dashboard	GET	/dashboard/ai-usage	AI provider usage (tokens, estimated or exact cost) and the credit left, if one is configured.	
Health	GET	/health	Health	
Health	GET	/db-health	Db health	

4.5 Support Agent - 44 endpoints

Module	Method	Endpoint	Purpose	Code needed
Sign-in & Account	POST	/auth/login	Signs in, or, for an account with two-step sign-in, answers `mfa_required` and opens the code step: send the code to /auth/mfa/verify.	
Sign-in & Account	POST	/auth/mfa/verify	The code step of a two-step sign-in: a code from the authenticator app, or a backup code.	
Sign-in & Account	GET	/auth/mfa	Mfa status	
Sign-in & Account	POST	/auth/mfa/setup	Start setting up an authenticator app: scan the QR code (`otpauth_uri`) or type `secret`, then confirm with /auth/mfa/enable.	
Sign-in & Account	POST	/auth/mfa/enable	Confirm the setup with a code from the app.	
Sign-in & Account	POST	/auth/mfa/disable	Turn two-step sign-in off.	
Sign-in & Account	POST	/auth/mfa/recovery-codes	New backup codes (the old ones stop working).	
Sign-in & Account	POST	/auth/refresh	Refresh	
Sign-in & Account	POST	/auth/logout	Logout	
Sign-in & Account	GET	/auth/me	Me	
Sign-in & Account	POST	/auth/change-password	Change password	
Sign-in & Account	POST	/auth/forgot-password	Email a single-use reset link.	
Sign-in & Account	POST	/auth/reset-password	Set a new password from a reset link.	
Users	GET	/users/{user_id}	Get user	
Organizations	GET	/organizations/options	For the create and edit forms: the port range, the ports already in use, and the brand fonts.	
Organizations	GET	/organizations/me	The caller's organisation: name, branding and contact details.	
Organizations	GET	/organizations/{organization_id}/logo	Get logo	
Branches	GET	/branches	List branches	
Branches	GET	/branches/{branch_id}	Get branch	
Departments	GET	/departments	List departments	
Departments	GET	/departments/{department_id}	Get department	
Categories	GET	/categories	List categories	
Support Center	GET	/support/staff/me	The caller's own support duty, or null.	
Support Center	PATCH	/support/staff/me	Staff set their own availability.	
Support Center	GET	/support/categories	The ticket categories of the caller's organization (its own, or the defaults).	
Support Center	POST	/support/tickets	Raise a ticket (Users, Branch Managers, Organization Admins).	
Support Center	POST	/support/tickets/{ticket_id}/confirm	The creator confirms the destination team (the recommended one, or another).	
Support Center	GET	/support/tickets	box: mine (raised by me), queue (the queues I work or manage), assigned (to me), unassigned (in my queues), all (everything I may see, including what I oversee).	
Support Center	GET	/support/tickets/dashboard	Counts for one box: by status, team, priority, level and assignee; overdue and unassigned.	

Module	Method	Endpoint	Purpose	Code needed
Support Center	GET	/support/tickets/{ticket_id}	The ticket with its timeline (replies, the internal notes the caller may read, status changes, forwards, assignments), attachments and the actions the caller may take.	
Support Center	POST	/support/tickets/{ticket_id}/messages	A reply (visible to the creator), or with internal=true a note for the handling team only.	
Support Center	POST	/support/tickets/{ticket_id}/status	Staff: open -> in_progress / waiting_for_user / waiting_for_team -> resolved (with a note), resolved -> in_progress.	
Support Center	POST	/support/tickets/{ticket_id}/priority	The handling team changes the priority; the SLA due times follow it.	
Support Center	POST	/support/tickets/{ticket_id}/assign	Take the ticket (your own id: a member of its queue), or assign / reassign / unassign it (the queue's manager or lead).	
Support Center	GET	/support/tickets/{ticket_id}/assignees	The staff of the ticket's queue (or of a forwarding destination) with their availability and workload.	
Support Center	POST	/support/tickets/{ticket_id}/forward	Forward to Branch Support, Head Office Support or Technical Support (or `escalate`: one level up), with a reason and confirmed=true.	
Support Center	POST	/support/tickets/{ticket_id}/cancel	The creator withdraws a draft or open ticket; a queue manager cancels one with a note.	
Support Center	POST	/support/tickets/{ticket_id}/attachments	PDF, image, text, CSV, Word or Excel, up to 10 MB.	
Support Center	GET	/support/tickets/{ticket_id}/attachments/{attachment_id}	Download attachment	
Notifications	GET	/notifications	My notifications	
Notifications	POST	/notifications/read	Mark read	
Dashboard	GET	/dashboard/ai-usage	AI provider usage (tokens, estimated or exact cost) and the credit left, if one is configured.	
Health	GET	/health	Health	
Health	GET	/db-health	Db health	

5. Module-wise: inputs and rules

5.1 Sign-in & Account

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
POST	/auth/login	Signs in, or, for an account with two-step sign-in, answers `mfa_required` and opens the code step: send the code to /auth/mfa/verify.	yes	yes	yes	yes	yes	
POST	/auth/mfa/verify	The code step of a two-step sign-in: a code from the authenticator app, or a backup code.	yes	yes	yes	yes	yes	
GET	/auth/mfa	Mfa status	yes	yes	yes	yes	yes	
POST	/auth/mfa/setup	Start setting up an authenticator app: scan the QR code (`otpauth_uri`) or type `secret`, then confirm with /auth/mfa/enable.	yes	yes	yes	yes	yes	
POST	/auth/mfa/enable	Confirm the setup with a code from the app.	yes	yes	yes	yes	yes	
POST	/auth/mfa/disable	Turn two-step sign-in off.	yes	yes	yes	yes	yes	
POST	/auth/mfa/recovery-codes	New backup codes (the old ones stop working).	yes	yes	yes	yes	yes	
POST	/auth/refresh	Refresh	yes	yes	yes	yes	yes	
POST	/auth/logout	Logout	yes	yes	yes	yes	yes	
GET	/auth/me	Me	yes	yes	yes	yes	yes	
POST	/auth/change-password	Change password	yes	yes	yes	yes	yes	
POST	/auth/forgot-password	Email a single-use reset link.	yes	yes	yes	yes	yes	
POST	/auth/reset-password	Set a new password from a reset link.	yes	yes	yes	yes	yes	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

POST /auth/login - Signs in, or, for an account with two-step sign-in, answers `mfa_required` and opens the code step: send the code to /auth/mfa/verify.

body: JSON

Field	In	Type	Required	Rules
email	body	email	**Required**	valid email address
password	body	string	**Required**	1-1024 characters

POST /auth/mfa/verify - The code step of a two-step sign-in: a code from the authenticator app, or a backup code.

body: JSON | limit: 30 requests per 5 minutes per client address

Field	In	Type	Required	Rules
code	body	string	**Required**	6-32 characters

POST /auth/mfa/enable - Confirm the setup with a code from the app.

body: JSON | limit: 10 requests per 5 minutes per account

Field	In	Type	Required	Rules
`code`	body	string	**Required**	6-32 characters

POST /auth/mfa/disable - Turn two-step sign-in off.

body: JSON | limit: 10 requests per 5 minutes per account

Field	In	Type	Required	Rules
`password`	body	string	**Required**	1-1024 characters
`code`	body	string	**Required**	6-32 characters

POST /auth/mfa/recovery-codes - New backup codes (the old ones stop working).

body: JSON | limit: 10 requests per 5 minutes per account

Field	In	Type	Required	Rules
`code`	body	string	**Required**	6-32 characters

POST /auth/change-password - Change password

body: JSON

Field	In	Type	Required	Rules
`current_password`	body	string	**Required**	1-1024 characters
`new_password`	body	string	**Required**	12-128 characters; a capital letter (A-Z); a small letter (a-z); a digit (0-9); a symbol such as @ # $ % & * !; no space at the start or end; no character 4 or more times in a row; must not contain the person's name or email

POST /auth/forgot-password - Email a single-use reset link.

body: JSON | limit: 3 requests per 15 minutes per email; 10 requests per 15 minutes per client address

Field	In	Type	Required	Rules
`email`	body	email	**Required**	valid email address

POST /auth/reset-password - Set a new password from a reset link.

body: JSON

Field	In	Type	Required	Rules
`token`	body	string	**Required**	1-2048 characters
`new_password`	body	string	**Required**	12-128 characters; a capital letter (A-Z); a small letter (a-z); a digit (0-9); a symbol such as @ # $ % & * !; no space at the start or end; no character 4 or more times in a row; must not contain the person's name or email

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
403 Not allowed	`PERMISSION_DENIED`	You cannot manage content at this branch/department scope.	`acl.py: ensure_can_write_scope`
403 Not allowed	`CSRF_FAILED`	Missing or invalid CSRF token. Reload the page and try again.	`cookies.py: require_csrf`

Result	Reason	Message shown	Checked in
403 Not allowed	PERMISSION_DENIED	You do not have permission to perform this action.	dependencies.py: dependency
401 Not signed in	UNAUTHENTICATED	Authentication required.	dependencies.py: get_current_principal
401 Not signed in	INVALID_TOKEN	Invalid access token.	dependencies.py: get_current_principal
401 Not signed in	INVALID_TOKEN	Session is no longer valid.	dependencies.py: get_current_principal
401 Not signed in	ORGANIZATION_SUSPENDED	Organization is not active.	dependencies.py: get_current_principal
401 Not signed in	UNAUTHENTICATED	Authentication required.	router.py: refresh
403 Not allowed	PERMISSION_DENIED	This action requires an organization account.	scope.py: tenant_id
422 Invalid input	INVALID_CREDENTIALS	Current password is incorrect.	service.py: change_password
422 Invalid input	VALIDATION_ERROR	New password must differ from the current password.	service.py: change_password
401 Not signed in	INVALID_CREDENTIALS	Invalid email or password.	service.py: login
401 Not signed in	ORGANIZATION_SUSPENDED	Organization is not active.	service.py: login
422 Invalid input	MFA_NOT_ENABLED	Two-step sign-in is not on.	service.py: mfa_disable
422 Invalid input	INVALID_CREDENTIALS	Password is incorrect.	service.py: mfa_disable
422 Invalid input	INVALID_MFA_CODE	That code is not right. Enter the code your authenticator app shows now (backup codes can't turn it off). Lost your phone? Ask your admin to reset it.	service.py: mfa_disable
409 Conflict	MFA_ALREADY_ENABLED	Two-step sign-in is already on.	service.py: mfa_enable
422 Invalid input	MFA_NOT_SET_UP	Start the setup again: scan a new QR code.	service.py: mfa_enable
422 Invalid input	INVALID_MFA_CODE	That code is not right. Enter the code your authenticator app shows now.	service.py: mfa_enable
422 Invalid input	MFA_NOT_ENABLED	Two-step sign-in is not on.	service.py: mfa_new_recovery_codes
422 Invalid input	INVALID_MFA_CODE	That code is not right. Enter the code your authenticator app shows now.	service.py: mfa_new_recovery_codes
409 Conflict	MFA_ALREADY_ENABLED	Two-step sign-in is already on. Turn it off first to move it to another phone.	service.py: mfa_setup
401 Not signed in	INVALID_TOKEN	Invalid refresh token.	service.py: refresh
401 Not signed in	TOKEN_ROTATED	Session was just refreshed.	service.py: refresh
401 Not signed in	TOKEN_EXPIRED	Refresh token expired.	service.py: refresh
401 Not signed in	ORGANIZATION_SUSPENDED	Organization is not active.	service.py: refresh
422 Invalid input	VALIDATION_ERROR	New password must differ from the current password.	service.py: reset_password
401 Not signed in	ORGANIZATION_SUSPENDED	Organization is not active.	service.py: verify_mfa
401 Not signed in	INVALID_MFA_CODE	That code is not right. Enter the current code from your authenticator app, or a backup code.	service.py: verify_mfa
403 Not allowed	STEP_UP_SETUP_REQUIRED	This is an important action: it needs a code from an authenticator app. Turn on two-step sign-in (account menu > Two-step sign-in), then try again.	step_up.py: confirm_step_up
403 Not allowed	STEP_UP_REQUIRED	Enter the code from your authenticator app to confirm this action.	step_up.py: confirm_step_up
403 Not allowed	STEP_UP_CODE_USED	That code was already used. Wait for the next code in your app (up to 30 seconds) and enter it.	step_up.py: confirm_step_up
403 Not allowed	STEP_UP_INVALID	That code is not right. Enter the code your authenticator app shows now.	step_up.py: confirm_step_up

5.2 Users

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
POST	/users	Create user	**yes**	**yes**	**yes**	-	-	Yes
GET	/users	List users	**yes**	**yes**	**yes**	-	-	
GET	/users/stats	User stats	**yes**	**yes**	**yes**	-	-	
GET	/users/{user_id}	Get user	**yes**	**yes**	**yes**	**yes**	**yes**	
PATCH	/users/{user_id}	Update user	**yes**	**yes**	**yes**	-	-	Yes: only when email, role, is_active, organization, branch or department changes
DELETE	/users/{user_id}	Delete user	**yes**	**yes**	**yes**	-	-	Yes
POST	/users/{user_id}/reset-password	Reset password	**yes**	**yes**	**yes**	-	-	Yes
POST	/users/{user_id}/reset-mfa	Turn off a user's two-step sign-in (lost phone).	**yes**	**yes**	**yes**	-	-	Yes

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

POST /users - Create user

body: JSON | authenticator code: always

Field	In	Type	Required	Rules
email	body	email	**Required**	valid email address
full_name	body	string	**Required**	2-200 characters; letters, spaces, apostrophes, hyphens and dots only; at least 2 letters; extra spaces removed
password	body	string or null	optional	12-128 characters; a capital letter (A-Z); a small letter (a-z); a digit (0-9); a symbol such as @ # $ % & * !; no space at the start or end; no character 4 or more times in a row; must not contain the person's name or email
phone	body	string or null	optional	at most 30 characters; digits, spaces and + ( ) - . only; 7-15 digits; + only at the start; blank = none
role	body	Role	**Required**	one of: master_admin, org_admin, branch_manager, department_user, support_agent
organization_id	body	UUID or null	optional	valid UUID
branch_id	body	UUID or null	optional	valid UUID
new_branch	body	NewBranch or null	optional	-
new_branch.street_address	body	string	**Required**	2-300 characters; one line, no control characters; not blank; extra spaces removed
new_branch.state	body	string	**Required**	2-100 characters; one line; at least one letter or digit; no < or >; extra spaces removed
new_branch.postal_code	body	string	**Required**	pattern ^[A-Za-z0-9][A-Za-z0-9 -]{1,18}[A-Za-z0-9]$
new_branch.name	body	string	**Required**	2-200 characters; one line; at least one letter or digit; no < or >; extra spaces removed
department_id	body	UUID or null	optional	valid UUID

GET /users - List users

Field	In	Type	Required	Rules
search	query	string or null	optional	at most 100 characters
status	query	enum or null	optional	one of: active, inactive
limit	query	integer	optional	1 to 200; default 50
offset	query	integer	optional	>= 0; default 0

GET /users/{user_id} - Get user

Field	In	Type	Required	Rules
user_id	path	UUID	**Required**	valid UUID

PATCH /users/{user_id} - Update user

body: JSON | authenticator code: only when email, role, is_active, organization, branch or department changes

Field	In	Type	Required	Rules
user_id	path	UUID	**Required**	valid UUID
full_name	body	string or null	optional	2-200 characters; letters, spaces, apostrophes, hyphens and dots only; at least 2 letters; extra spaces removed
email	body	email or null	optional	valid email address
phone	body	string or null	optional	at most 30 characters; digits, spaces and + ( ) - . only; 7-15 digits; + only at the start; blank = none
organization_id	body	UUID or null	optional	valid UUID
is_active	body	true/false or null	optional	-
role	body	Role or null	optional	one of: master_admin, org_admin, branch_manager, department_user, support_agent
branch_id	body	UUID or null	optional	valid UUID
department_id	body	UUID or null	optional	valid UUID

DELETE /users/{user_id} - Delete user

authenticator code: always

Field	In	Type	Required	Rules
user_id	path	UUID	**Required**	valid UUID

POST /users/{user_id}/reset-password - Reset password

body: JSON | authenticator code: always

Field	In	Type	Required	Rules
user_id	path	UUID	**Required**	valid UUID
new_password	body	string or null	optional	12-128 characters; a capital letter (A-Z); a small letter (a-z); a digit (0-9); a symbol such as @ # $ % & * !; no space at the start or end; no character 4 or more times in a row; must not contain the person's name or email

POST /users/{user_id}/reset-mfa - Turn off a user's two-step sign-in (lost phone).

authenticator code: always

Field	In	Type	Required	Rules
user_id	path	UUID	**Required**	valid UUID

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
403 Not allowed	PERMISSION_DENIED	You cannot create branches.	service.py: _new_branch
422 Invalid input	BRANCH_EXISTS	A branch named “<name>” already exists. Choose it from the list.	service.py: _new_branch
403 Not allowed	PERMISSION_DENIED	You cannot assign the role <role>.	service.py: _resolve_scope
422 Invalid input	VALIDATION_ERROR	A valid organization_id is required.	service.py: _resolve_scope
422 Invalid input	VALIDATION_ERROR	A valid branch_id in this organization is required.	service.py: _resolve_scope
422 Invalid input	VALIDATION_ERROR	The department does not belong to the selected branch.	service.py: _resolve_scope
403 Not allowed	PERMISSION_DENIED	You cannot assign the role <role>.	service.py: create
422 Invalid input	EMAIL_TAKEN	A user with this email already exists.	service.py: create
422 Invalid input	EMAIL_TAKEN	A user with this email already exists.	service.py: create_master_admin
404 Not found	NOT_FOUND	User not found.	service.py: delete
422 Invalid input	VALIDATION_ERROR	You cannot delete yourself.	service.py: delete
404 Not found	NOT_FOUND	User not found.	service.py: get
404 Not found	NOT_FOUND	User not found.	service.py: reset_mfa
422 Invalid input	VALIDATION_ERROR	Turn your own two-step sign-in off from your account menu.	service.py: reset_mfa
422 Invalid input	MFA_NOT_ENABLED	Two-step sign-in is not on for this user.	service.py: reset_mfa
404 Not found	NOT_FOUND	User not found.	service.py: reset_password
403 Not allowed	PERMISSION_DENIED	Only the Master Admin can move a user to another organization.	service.py: update
404 Not found	NOT_FOUND	User not found.	service.py: update
409 Conflict	USER_HAS_SIGNED_IN	<full_name> has signed in before, so the account stays with its organization. Add a new account in the other organization instead.	service.py: update
422 Invalid input	VALIDATION_ERROR	You cannot deactivate yourself or change your own role.	service.py: update
422 Invalid input	EMAIL_TAKEN	A user with this email already exists.	service.py: update

5.3 Organizations

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
POST	/organizations	Create an organisation (with branding) and, optionally, its first admin.	**yes**	-	-	-	-	
GET	/organizations	List organizations	**yes**	-	-	-	-	
GET	/organizations/options	For the create and edit forms: the port range, the ports already in use, and the brand fonts.	**yes**	**yes**	**yes**	**yes**	**yes**	
GET	/organizations/me	The caller's organisation: name, branding and contact details.	**yes**	**yes**	**yes**	**yes**	**yes**	
GET	/organizations/{organization_id}	Get organization	**yes**	-	-	-	-	
PATCH	/organizations/{organization_id}	Update organization	**yes**	-	-	-	-	Yes: only when the status changes (suspend / reactivate)
GET	/organizations/{organization_id}/delete-preview	What deleting the organisation would also delete: its branches, departments, users and policies.	**yes**	-	-	-	-	
DELETE	/organizations/{organization_id}	Soft-delete the organisation and everything in it.	**yes**	-	-	-	-	Yes: only the real deletion (confirm=true), not the preview
POST	/organizations/{organization_id}/logo	Upload logo	**yes**	-	-	-	-	
GET	/organizations/{organization_id}/logo	Get logo	**yes**	**yes**	**yes**	**yes**	**yes**	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

POST /organizations - Create an organisation (with branding) and, optionally, its first admin.

body: JSON

Field	In	Type	Required	Rules
primary_color	body	string or null	optional	pattern ^#[0-9a-fA-F]{6}$
secondary_color	body	string or null	optional	pattern ^#[0-9a-fA-F]{6}$
brand_font	body	string or null	optional	-
contact_email	body	email or null	optional	valid email address
contact_phone	body	string or null	optional	at most 30 characters; digits, spaces and + ( ) - . only; 7-15 digits; + only at the start; blank = none
website	body	string or null	optional	at most 300 characters; starts with http:// or https://; no spaces; blank = none
address	body	string or null	optional	at most 2000 characters; line breaks allowed, no control characters; trimmed; blank = not given
allowed_port	body	integer or null	optional	-
name	body	string	**Required**	2-200 characters; one line; at least one letter or digit; no < or >; extra spaces removed
slug	body	string	**Required**	pattern ^[a-z0-9][a-z0-9-]{1,98}[a-z0-9]$
admin	body	FirstAdmin or null	optional	-
admin.email	body	email	**Required**	valid email address
admin.full_name	body	string	**Required**	2-200 characters; letters, spaces, apostrophes, hyphens and dots only; at least 2 letters; extra spaces removed
admin.password	body	string	**Required**	12-128 characters; a capital letter (A-Z); a small letter (a-z); a digit (0-9); a symbol such as @ # $ % & * !; no space at the start or end; no character 4 or more times in a row; must not contain the person's name or email

GET /organizations - List organizations

Field	In	Type	Required	Rules
`limit`	query	integer	optional	1 to 200; default 50
`offset`	query	integer	optional	>= 0; default 0

GET /organizations/{organization_id} - Get organization

Field	In	Type	Required	Rules
`organization_id`	path	UUID	**Required**	valid UUID

PATCH /organizations/{organization_id} - Update organization

body: JSON | authenticator code: only when the status changes (suspend / reactivate)

Field	In	Type	Required	Rules
`organization_id`	path	UUID	**Required**	valid UUID
`primary_color`	body	string or null	optional	pattern ^#[0-9a-fA-F]{6}$
`secondary_color`	body	string or null	optional	pattern ^#[0-9a-fA-F]{6}$
`brand_font`	body	string or null	optional	-
`contact_email`	body	email or null	optional	valid email address
`contact_phone`	body	string or null	optional	at most 30 characters; digits, spaces and + ( ) - . only; 7-15 digits; + only at the start; blank = none
`website`	body	string or null	optional	at most 300 characters; starts with http:// or https://; no spaces; blank = none
`address`	body	string or null	optional	at most 2000 characters; line breaks allowed, no control characters; trimmed; blank = not given
`allowed_port`	body	integer or null	optional	-
`name`	body	string or null	optional	2-200 characters; one line; at least one letter or digit; no < or >; extra spaces removed
`status`	body	OrganizationStatus or null	optional	one of: active, suspended

GET /organizations/{organization_id}/delete-preview - What deleting the organisation would also delete: its branches, departments, users and policies.

Field	In	Type	Required	Rules
`organization_id`	path	UUID	**Required**	valid UUID

DELETE /organizations/{organization_id} - Soft-delete the organisation and everything in it.

authenticator code: only the real deletion (confirm=true), not the preview

Field	In	Type	Required	Rules
`organization_id`	path	UUID	**Required**	valid UUID
`confirm`	query	true/false	optional	default false

POST /organizations/{organization_id}/logo - Upload logo

body: form / file upload

Field	In	Type	Required	Rules
`organization_id`	path	UUID	**Required**	valid UUID
`file`	body	file	**Required**	-

GET /organizations/{organization_id}/logo - Get logo

Field	In	Type	Required	Rules
`organization_id`	path	UUID	**Required**	valid UUID

Extra checks on the input

Schema	Check	What it does
`Branding`	known font	-

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
422 Invalid input	`VALIDATION_ERROR`	You cannot delete the <type> you belong to.	`hierarchy.py: delete`
404 Not found	`NOT_FOUND`	Organization not found.	`router.py: get_logo`
404 Not found	`NOT_FOUND`	No logo.	`router.py: get_logo`
404 Not found	`NOT_FOUND`	You do not belong to an organization.	`router.py: my_organization`
409 Conflict	`PORT_TAKEN`	Port <port> is already used by <name>.	`service.py: _check_port`
422 Invalid input	`PORT_OUT_OF_RANGE`	Choose a port between <low> and <high>.	`service.py: _check_port`
422 Invalid input	`EMAIL_TAKEN`	A user with this email already exists.	`service.py: create`
404 Not found	`NOT_FOUND`	Organization not found.	`service.py: get`
413 Too large	`PAYLOAD_TOO_LARGE`	The logo must be 2 MB or smaller.	`service.py: set_logo`
422 Invalid input	`UNSUPPORTED_FILE_TYPE`	Upload the logo as PNG, JPEG or WebP.	`service.py: set_logo`
422 Invalid input	`UNSUPPORTED_FILE_TYPE`	The file is not a valid image.	`service.py: set_logo`

5.4 Branches

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
POST	/branches	Create branch	-	yes	-	-	-	
GET	/branches	List branches	yes	yes	yes	yes	yes	
GET	/branches/{branch_id}	Get branch	yes	yes	yes	yes	yes	
PATCH	/branches/{branch_id}	Update branch	-	yes	-	-	-	
GET	/branches/{branch_id}/delete-preview	What deleting the branch would also delete: its departments, users and policies.	-	yes	-	-	-	
DELETE	/branches/{branch_id}	Soft-delete the branch and everything in it.	-	yes	-	-	-	Yes: only the real deletion (confirm=true), not the preview

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

POST /branches - Create branch

body: JSON

Field	In	Type	Required	Rules
street_address	body	string	**Required**	2-300 characters; one line, no control characters; not blank; extra spaces removed
state	body	string	**Required**	2-100 characters; one line; at least one letter or digit; no < or >; extra spaces removed
postal_code	body	string	**Required**	pattern ^[A-Za-z0-9][A-Za-z0-9 -]{1,18}[A-Za-z0-9]$
name	body	string	**Required**	2-200 characters; one line; at least one letter or digit; no < or >; extra spaces removed
code	body	string	**Required**	pattern ^[A-Za-z0-9][A-Za-z0-9_-]{0,49}$

GET /branches - List branches

Field	In	Type	Required	Rules
limit	query	integer	optional	1 to 200; default 50
offset	query	integer	optional	>= 0; default 0

GET /branches/{branch_id} - Get branch

Field	In	Type	Required	Rules
branch_id	path	UUID	**Required**	valid UUID

PATCH /branches/{branch_id} - Update branch

body: JSON

Field	In	Type	Required	Rules
branch_id	path	UUID	**Required**	valid UUID
name	body	string or null	optional	2-200 characters; one line; at least one letter or digit; no < or >; extra spaces removed
street_address	body	string or null	optional	2-300 characters; one line, no control characters; not blank; extra spaces removed
state	body	string or null	optional	2-100 characters; one line; at least one letter or digit; no < or >; extra spaces removed
postal_code	body	string or null	optional	pattern ^[A-Za-z0-9][A-Za-z0-9 -]{1,18}[A-Za-z0-9]$
is_active	body	true/false or null	optional	-

GET /branches/{branch_id}/delete-preview - What deleting the branch would also delete: its departments, users and policies.

Field	In	Type	Required	Rules
branch_id	path	UUID	**Required**	valid UUID

DELETE /branches/{branch_id} - Soft-delete the branch and everything in it.

authenticator code: only the real deletion (confirm=true), not the preview

Field	In	Type	Required	Rules
branch_id	path	UUID	**Required**	valid UUID
confirm	query	true/false	optional	default false

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
404 Not found	NOT_FOUND	Branch not found.	service.py: get

5.5 Departments

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
POST	/departments	Create department	-	yes	yes	-	-	
GET	/departments	List departments	yes	yes	yes	yes	yes	
GET	/departments/{department_id}	Get department	yes	yes	yes	yes	yes	
PATCH	/departments/{department_id}	Update department	-	yes	yes	-	-	
GET	/departments/{department_id}/delete-preview	What deleting the department would also delete: its users and policies.	-	yes	yes	-	-	
DELETE	/departments/{department_id}	Soft-delete the department and its users.	-	yes	yes	-	-	Yes: only the real deletion (confirm=true), not the preview

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

POST /departments - Create department

body: JSON

Field	In	Type	Required	Rules
branch_id	body	UUID	**Required**	valid UUID
name	body	string	**Required**	2-200 characters; one line; at least one letter or digit; no < or >; extra spaces removed
code	body	string	**Required**	pattern ^[A-Za-z0-9][A-Za-z0-9_-]{0,49}$

GET /departments - List departments

Field	In	Type	Required	Rules
branch_id	query	UUID or null	optional	valid UUID
limit	query	integer	optional	1 to 200; default 50
offset	query	integer	optional	>= 0; default 0

GET /departments/{department_id} - Get department

Field	In	Type	Required	Rules
department_id	path	UUID	**Required**	valid UUID

PATCH /departments/{department_id} - Update department

body: JSON

Field	In	Type	Required	Rules
department_id	path	UUID	**Required**	valid UUID
name	body	string or null	optional	2-200 characters; one line; at least one letter or digit; no < or >; extra spaces removed
is_active	body	true/false or null	optional	-

GET /departments/{department_id}/delete-preview - What deleting the department would also delete: its users and policies.

Field	In	Type	Required	Rules
department_id	path	UUID	**Required**	valid UUID

DELETE /departments/{department_id} - Soft-delete the department and its users.

authenticator code: only the real deletion (confirm=true), not the preview

Field	In	Type	Required	Rules
`department_id`	path	UUID	**Required**	valid UUID
`confirm`	query	true/false	optional	default false

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
403 Not allowed	`PERMISSION_DENIED`	You can only manage departments in your own branch.	`service.py: _check_branch_access`
404 Not found	`NOT_FOUND`	Branch not found.	`service.py: create`
404 Not found	`NOT_FOUND`	Department not found.	`service.py: get`

5.6 Categories

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/categories	List categories	yes	yes	yes	yes	yes	
GET	/categories/overview	Every category with its policy count and last activity (over what the caller can see).	-	yes	yes	yes	-	
POST	/categories	Create category	-	yes	-	-	-	
GET	/categories/{category_id}	Get category	-	yes	yes	yes	-	
PATCH	/categories/{category_id}	Update category	-	yes	-	-	-	
GET	/categories/{category_id}/documents	Policies in the category with every version and the file behind it.	-	yes	yes	yes	-	
GET	/categories/{category_id}/pending	Files uploaded into the category that are still processing or waiting for review.	-	yes	yes	yes	-	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

GET /categories - List categories

Field	In	Type	Required	Rules
include_inactive	query	true/false	optional	default false

GET /categories/overview - Every category with its policy count and last activity (over what the caller can see).

Field	In	Type	Required	Rules
include_inactive	query	true/false	optional	default true

POST /categories - Create category

body: JSON

Field	In	Type	Required	Rules
name	body	string	**Required**	2-100 characters; one line; at least one letter or digit; no < or >; extra spaces removed
category_type	body	CategoryType	**Required**	one of: policy, circular, sop, guideline, manual, notice, process_document, form, faq, regulatory_document, other
description	body	string or null	optional	at most 2000 characters; line breaks allowed, no control characters; trimmed; blank = not given
is_active	body	true/false	optional	default true
slug	body	string or null	optional	pattern ^[a-z0-9][a-z0-9-]{0,98}[a-z0-9]$
authority_rank	body	integer or null	optional	0.0 to 1000.0
keywords	body	list of string	optional	at most 100 items; each: 1-50 characters; each: one item, no commas; each: no < or >

GET /categories/{category_id} - Get category

Field	In	Type	Required	Rules
category_id	path	UUID	**Required**	valid UUID

PATCH /categories/{category_id} - Update category

body: JSON

Field	In	Type	Required	Rules
`category_id`	path	UUID	**Required**	valid UUID
`name`	body	string or null	optional	2-100 characters; one line; at least one letter or digit; no < or >; extra spaces removed
`category_type`	body	CategoryType or null	optional	one of: policy, circular, sop, guideline, manual, notice, process_document, form, faq, regulatory_document, other
`description`	body	string or null	optional	at most 2000 characters; line breaks allowed, no control characters; trimmed; blank = not given
`authority_rank`	body	integer or null	optional	0.0 to 1000.0
`keywords`	body	list of string or null	optional	at most 100 items; each: 1-50 characters; each: one item, no commas; each: no < or >
`is_active`	body	true/false or null	optional	-

GET /categories/{category_id}/documents - Policies in the category with every version and the file behind it.

Field	In	Type	Required	Rules
`category_id`	path	UUID	**Required**	valid UUID
`search`	query	string or null	optional	at most 200 characters
`status`	query	enum or null	optional	one of: active, archived
`version_state`	query	enum or null	optional	one of: current, historical, scheduled, withdrawn
`sort`	query	enum	optional	one of: custom, name, uploaded, version; default "custom"
`limit`	query	integer	optional	1 to 200; default 50
`offset`	query	integer	optional	>= 0; default 0

GET /categories/{category_id}/pending - Files uploaded into the category that are still processing or waiting for review.

Field	In	Type	Required	Rules
`category_id`	path	UUID	**Required**	valid UUID

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
409 Conflict	`DUPLICATE_CATEGORY`	A category named "<name>" already exists.	`service.py: _ensure_name_free`
409 Conflict	`CONFLICT`	A category with this slug already exists.	`service.py: create`
404 Not found	`NOT_FOUND`	Category not found.	`service.py: get`

5.7 Policies & Versions

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/policies	List policies	-	yes	yes	yes	-	
POST	/policies	Create a policy by hand (global or branch); upload its documents into it afterwards.	-	yes	yes	-	-	
GET	/policies/{policy_id}	Get policy	-	yes	yes	yes	-	
PATCH	/policies/{policy_id}	Update policy	-	yes	yes	-	-	
GET	/policies/{policy_id}/versions	Every version, newest first, with the file behind it and who uploaded it.	-	yes	yes	yes	-	
GET	/policies/{policy_id}/versions/{version_id}	Get version	-	yes	yes	yes	-	
GET	/policies/{policy_id}/compare	Deterministic side-by-side comparison; original text of both versions is included.	-	yes	yes	yes	-	
POST	/policies/{policy_id}/versions/{version_id}/withdraw	Withdraw version	-	yes	yes	-	-	Yes
POST	/policies/{policy_id}/versions/{version_id}/restore	Activate an archived version: it rejoins the effective-date timeline.	-	yes	yes	-	-	Yes
PUT	/policies/{policy_id}/versions/order	Drag-and-drop version order, newest first: it becomes the timeline and the first is the latest.	-	yes	yes	-	-	
POST	/policies/{policy_id}/versions/{version_id}/move	Move a document to another policy's version group (requires confirm=true).	-	yes	yes	-	-	
GET	/policies/{policy_id}/versions/{version_id}/summary	AI summary of the version (labelled AI-generated) with dates and changes from the database.	-	yes	yes	yes	-	
POST	/policies/{policy_id}/versions/{version_id}/summary	Regenerate summary	-	yes	yes	-	-	
DELETE	/policies/{policy_id}	Delete a policy permanently, with every version, document and stored file.	-	yes	yes	-	-	Yes
POST	/policies/{policy_id}/move	Arrange a document within its category.	-	yes	yes	-	-	
POST	/documents/{document_id}/relationships	Add relationship	-	yes	yes	-	-	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

GET /policies - List policies

Field	In	Type	Required	Rules
search	query	string or null	optional	at most 200 characters
category_id	query	UUID or null	optional	valid UUID
status	query	string or null	optional	pattern ^(active|archived)$
as_of	query	date or null	optional	YYYY-MM-DD
limit	query	integer	optional	1 to 200; default 50
offset	query	integer	optional	>= 0; default 0

POST /policies - Create a policy by hand (global or branch); upload its documents into it afterwards.

body: JSON

Field	In	Type	Required	Rules
`name`	body	string	**Required**	2-500 characters; one line; at least one letter or digit; no < or >; extra spaces removed
`category_id`	body	UUID	**Required**	valid UUID
`scope`	body	enum	optional	one of: global, branch; default "branch"
`branch_id`	body	UUID or null	optional	valid UUID
`department_id`	body	UUID or null	optional	valid UUID
`description`	body	string or null	optional	at most 5000 characters; line breaks allowed, no control characters; trimmed; blank = not given
`policy_number`	body	string or null	optional	at most 100 characters; one line, no control characters; extra spaces removed; blank = not given
`owner`	body	string or null	optional	at most 200 characters; one line, no control characters; extra spaces removed; blank = not given

GET /policies/{policy_id} - Get policy

Field	In	Type	Required	Rules
`policy_id`	path	UUID	**Required**	valid UUID

PATCH /policies/{policy_id} - Update policy

body: JSON

Field	In	Type	Required	Rules
`policy_id`	path	UUID	**Required**	valid UUID
`name`	body	string or null	optional	2-500 characters; one line; at least one letter or digit; no < or >; extra spaces removed
`category_id`	body	UUID or null	optional	valid UUID
`issuer`	body	string or null	optional	at most 200 characters; one line, no control characters; extra spaces removed; blank = not given
`issuing_department`	body	string or null	optional	at most 200 characters; one line, no control characters; extra spaces removed; blank = not given
`owner`	body	string or null	optional	at most 200 characters; one line, no control characters; extra spaces removed; blank = not given
`description`	body	string or null	optional	at most 5000 characters; line breaks allowed, no control characters; trimmed; blank = not given
`status`	body	string or null	optional	pattern ^(active|archived)$

GET /policies/{policy_id}/versions - Every version, newest first, with the file behind it and who uploaded it.

Field	In	Type	Required	Rules
`policy_id`	path	UUID	**Required**	valid UUID

GET /policies/{policy_id}/versions/{version_id} - Get version

Field	In	Type	Required	Rules
`policy_id`	path	UUID	**Required**	valid UUID
`version_id`	path	UUID	**Required**	valid UUID

GET /policies/{policy_id}/compare - Deterministic side-by-side comparison; original text of both versions is included.

Field	In	Type	Required	Rules
`policy_id`	path	UUID	**Required**	valid UUID
`base`	query	UUID	**Required**	valid UUID
`target`	query	UUID	**Required**	valid UUID

POST /policies/{policy_id}/versions/{version_id}/withdraw - Withdraw version

body: JSON | authenticator code: always

Field	In	Type	Required	Rules
`policy_id`	path	UUID	**Required**	valid UUID
`version_id`	path	UUID	**Required**	valid UUID
`reason`	body	string	**Required**	5-2000 characters; line breaks allowed, no control characters; not blank; trimmed

POST /policies/{policy_id}/versions/{version_id}/restore - Activate an archived version: it rejoins the effective-date timeline.

authenticator code: always

Field	In	Type	Required	Rules
`policy_id`	path	UUID	**Required**	valid UUID
`version_id`	path	UUID	**Required**	valid UUID

PUT /policies/{policy_id}/versions/order - Drag-and-drop version order, newest first: it becomes the timeline and the first is the latest.

body: JSON

Field	In	Type	Required	Rules
`policy_id`	path	UUID	**Required**	valid UUID
`version_ids`	body	list of UUID	**Required**	1-1000 items; each: valid UUID
`confirm_latest_change`	body	true/false	optional	default false

POST /policies/{policy_id}/versions/{version_id}/move - Move a document to another policy's version group (requires confirm=true).

body: JSON

Field	In	Type	Required	Rules
`policy_id`	path	UUID	**Required**	valid UUID
`version_id`	path	UUID	**Required**	valid UUID
`target_policy_id`	body	UUID	**Required**	valid UUID
`confirm`	body	true/false	optional	default false

GET /policies/{policy_id}/versions/{version_id}/summary - AI summary of the version (labelled AI-generated) with dates and changes from the database.

Field	In	Type	Required	Rules
`policy_id`	path	UUID	**Required**	valid UUID
`version_id`	path	UUID	**Required**	valid UUID

POST /policies/{policy_id}/versions/{version_id}/summary - Regenerate summary

Field	In	Type	Required	Rules
policy_id	path	UUID	**Required**	valid UUID
version_id	path	UUID	**Required**	valid UUID

DELETE /policies/{policy_id} - Delete a policy permanently, with every version, document and stored file.

authenticator code: always

Field	In	Type	Required	Rules
policy_id	path	UUID	**Required**	valid UUID

POST /policies/{policy_id}/move - Arrange a document within its category.

body: JSON

Field	In	Type	Required	Rules
policy_id	path	UUID	**Required**	valid UUID
after_id	body	UUID or null	optional	valid UUID
before_id	body	UUID or null	optional	valid UUID

POST /documents/{document_id}/relationships - Add relationship

body: JSON

Field	In	Type	Required	Rules
document_id	path	UUID	**Required**	valid UUID
relation_type	body	string	**Required**	at most 50 characters
target_policy_id	body	UUID	**Required**	valid UUID
target_version_id	body	UUID or null	optional	valid UUID
clauses	body	list of string	optional	at most 100 items; each: at most 200 characters; each: one line, no control characters; each: not blank; each: extra spaces removed
evidence	body	string or null	optional	at most 2000 characters; line breaks allowed, no control characters; trimmed; blank = not given

Extra checks on the input

Schema	Check	What it does
DocumentMove	one anchor	-

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
404 Not found	NOT_FOUND	Document not found.	service.py: add_relationship
422 Invalid input	VALIDATION_ERROR	Unknown relation type <relation_type>.	service.py: add_relationship
422 Invalid input	VALIDATION_ERROR	Target version does not belong to the related policy.	service.py: add_relationship
403 Not allowed	PERMISSION_DENIED	Only organisation admins create global policies.	service.py: create
422 Invalid input	VALIDATION_ERROR	Category not found.	service.py: create

Result	Reason	Message shown	Checked in
422 Invalid input	VALIDATION_ERROR	Choose the branch for a branch policy.	service.py: create
422 Invalid input	VALIDATION_ERROR	Branch not found.	service.py: create
422 Invalid input	VALIDATION_ERROR	Department not found in the selected branch.	service.py: create
422 Invalid input	VALIDATION_ERROR	Policy name is required.	service.py: create
409 Conflict	INVALID_STATE	A document of this policy is still being processed. Delete the policy once processing finishes.	service.py: delete
404 Not found	NOT_FOUND	Policy not found.	service.py: get
422 Invalid input	VALIDATION_ERROR	The other document is not in this category.	service.py: move
409 Conflict	INVALID_STATE	The target policy is archived.	service.py: move_version
409 Conflict	MOVE_REQUIRES_CONFIRMATION	Moving version <version_label> from "<name>" to "<name>" changes which policy it belongs to. Confirm to continue.	service.py: move_version
422 Invalid input	VALIDATION_ERROR	Choose a different policy.	service.py: move_version
409 Conflict	LATEST_CHANGE_REQUIRES_CONFIRMATION	This order changes which version is in force. Confirm to make it the latest version.	service.py: reorder
422 Invalid input	VALIDATION_ERROR	List every active version of the policy exactly once, newest first.	service.py: reorder
422 Invalid input	VALIDATION_ERROR	Only withdrawn versions can be restored.	service.py: restore
422 Invalid input	VALIDATION_ERROR	Category not found.	service.py: update
404 Not found	NOT_FOUND	Version not found.	service.py: version
422 Invalid input	VALIDATION_ERROR	Only active versions can be withdrawn.	service.py: withdraw

5.8 Policy Versions (shared rules)

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
409 Conflict	`VERSION_CONFLICT`	Version <version_label> is already effective from <isoformat>.	`timeline.py: _make_room`
409 Conflict	`VERSION_CONFLICT`	The effective period overlaps the next version.	`timeline.py: insert_version`
422 Invalid input	`VALIDATION_ERROR`	effective_to must be after effective_from.	`timeline.py: insert_version`
409 Conflict	`VERSION_ORDER_CONFLICT`	Version <version_label> is effective from <isoformat> (<stated>), so it cannot come before version <version_label>. Change its effective date to reorder these versions.	`timeline.py: plan_order`

5.9 Documents

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
POST	/documents	Upload document	-	yes	yes	-	-	
GET	/documents/upload-limits	What the server accepts, so files can be checked before they are sent.	-	yes	yes	-	-	
POST	/documents/duplicates	Which files (SHA-256 computed in the browser) already exist, before anything is uploaded.	-	yes	yes	-	-	
GET	/documents	List documents	-	yes	yes	yes	-	
GET	/documents/{document_id}	Get document	-	yes	yes	yes	-	
GET	/documents/{document_id}/progress	Get progress	-	yes	yes	yes	-	
GET	/documents/{document_id}/file	Download file	-	yes	yes	yes	-	
PATCH	/documents/{document_id}	Update document	-	yes	yes	-	-	
POST	/documents/{document_id}/archive	Archive document	-	yes	yes	-	-	
DELETE	/documents/{document_id}	Delete a document permanently, with its version, chunks and stored file.	-	yes	yes	-	-	Yes
POST	/documents/{document_id}/retry	Retry document	-	yes	yes	-	-	
GET	/documents/{document_id}/pages/{page_number}/image	PNG of one page; `highlight_chunk` marks a cited passage on the page.	-	yes	yes	yes	-	
GET	/documents/{document_id}/pages/{page_number}	Get page text	-	yes	yes	yes	-	
GET	/documents/{document_id}/outline	Get outline	-	yes	yes	yes	-	
GET	/documents/{document_id}/chunks/{chunk_id}	Get chunk	-	yes	yes	yes	-	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

POST /documents - Upload document

body: form / file upload

Field	In	Type	Required	Rules
file	body	file	**Required**	-
branch_id	body	UUID or null	optional	valid UUID
department_id	body	UUID or null	optional	valid UUID
category_id	body	UUID or null	optional	valid UUID
allow_duplicate	body	true/false	optional	default false
duplicate_reason	body	string or null	optional	at most 1000 characters

POST /documents/duplicates - Which files (SHA-256 computed in the browser) already exist, before anything is uploaded.

body: JSON

Field	In	Type	Required	Rules
sha256	body	list of string	**Required**	1-500 items

GET /documents - List documents

Field	In	Type	Required	Rules
`status`	query	string or null	optional	-
`category_id`	query	UUID or null	optional	valid UUID
`policy_id`	query	UUID or null	optional	valid UUID
`branch_id`	query	UUID or null	optional	valid UUID
`department_id`	query	UUID or null	optional	valid UUID
`search`	query	string or null	optional	at most 200 characters
`limit`	query	integer	optional	1 to 200; default 50
`offset`	query	integer	optional	>= 0; default 0

GET /documents/{document_id} - Get document

Field	In	Type	Required	Rules
`document_id`	path	UUID	**Required**	valid UUID

GET /documents/{document_id}/progress - Get progress

Field	In	Type	Required	Rules
`document_id`	path	UUID	**Required**	valid UUID

GET /documents/{document_id}/file - Download file

Field	In	Type	Required	Rules
`document_id`	path	UUID	**Required**	valid UUID

PATCH /documents/{document_id} - Update document

body: JSON

Field	In	Type	Required	Rules
`document_id`	path	UUID	**Required**	valid UUID
`title`	body	string or null	optional	1-500 characters; one line; at least one letter or digit; no < or >; extra spaces removed
`category_id`	body	UUID or null	optional	valid UUID
`branch_id`	body	UUID or null	optional	valid UUID
`department_id`	body	UUID or null	optional	valid UUID

POST /documents/{document_id}/archive - Archive document

Field	In	Type	Required	Rules
`document_id`	path	UUID	**Required**	valid UUID

DELETE /documents/{document_id} - Delete a document permanently, with its version, chunks and stored file.

authenticator code: always

Field	In	Type	Required	Rules
`document_id`	path	UUID	**Required**	valid UUID

POST /documents/{document_id}/retry - Retry document

Field	In	Type	Required	Rules
document_id	path	UUID	**Required**	valid UUID

GET /documents/{document_id}/pages/{page_number}/image - PNG of one page; `highlight_chunk` marks a cited passage on the page.

Field	In	Type	Required	Rules
document_id	path	UUID	**Required**	valid UUID
page_number	path	integer	**Required**	-
zoom	query	number	optional	default 1.5
highlight_chunk	query	UUID or null	optional	valid UUID
audit	query	true/false	optional	default false

GET /documents/{document_id}/pages/{page_number} - Get page text

Field	In	Type	Required	Rules
document_id	path	UUID	**Required**	valid UUID
page_number	path	integer	**Required**	-

GET /documents/{document_id}/outline - Get outline

Field	In	Type	Required	Rules
document_id	path	UUID	**Required**	valid UUID

GET /documents/{document_id}/chunks/{chunk_id} - Get chunk

Field	In	Type	Required	Rules
document_id	path	UUID	**Required**	valid UUID
chunk_id	path	UUID	**Required**	valid UUID

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
404 Not found	NOT_FOUND	Passage not found.	router.py: get_chunk
404 Not found	NOT_FOUND	Document not found.	service.py: _get_manageable
422 Invalid input	VALIDATION_ERROR	Department not found.	service.py: _resolve_scope
422 Invalid input	VALIDATION_ERROR	Department does not belong to the selected branch.	service.py: _resolve_scope
422 Invalid input	VALIDATION_ERROR	Branch not found.	service.py: _resolve_scope
409 Conflict	INVALID_STATE	This document is still being processed. Delete it once processing finishes or fails.	service.py: delete
404 Not found	NOT_FOUND	Document not found.	service.py: get
413 Too large	PAYLOAD_TOO_LARGE	File exceeds the maximum upload size of <max_bytes // (1024 * 1024> MB.	service.py: read
409 Conflict	INVALID_STATE	Only failed documents can be retried.	service.py: retry
422 Invalid input	VALIDATION_ERROR	Category not found.	service.py: update
422 Invalid input	VALIDATION_ERROR	Category not found.	service.py: upload
422 Invalid input	UNSUPPORTED_FILE_TYPE	Only PDF documents are supported.	service.py: upload

Result	Reason	Message shown	Checked in
422 Invalid input	`UNSUPPORTED_FILE_TYPE`	The file is not a valid PDF.	`service.py: upload`
422 Invalid input	`VALIDATION_ERROR`	The file is empty.	`service.py: upload`
422 Invalid input	`DUPLICATE_REASON_REQUIRED`	A reason is required to upload a duplicate document.	`service.py: upload`
404 Not found	`NOT_FOUND`	Page not found.	`viewer.py: page_text`
404 Not found	`NOT_FOUND`	Page not found.	`viewer.py: render_page`
404 Not found	`NOT_FOUND`	Highlight not found.	`viewer.py: render_page`
422 Invalid input	`VALIDATION_ERROR`	zoom must be between 0.25 and <MAX_ZOOM>.	`viewer.py: render_page`

5.10 Document Ingestion

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/documents/{document_id}/analysis	Get analysis	-	yes	yes	yes	-	
POST	/documents/{document_id}/confirm	Accept, adjust or reject the system's suggestion for an uploaded document.	-	yes	yes	-	-	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

GET /documents/{document_id}/analysis - Get analysis

Field	In	Type	Required	Rules
document_id	path	UUID	**Required**	valid UUID

POST /documents/{document_id}/confirm - Accept, adjust or reject the system's suggestion for an uploaded document.

body: JSON

Field	In	Type	Required	Rules
document_id	path	UUID	**Required**	valid UUID
action	body	enum	**Required**	one of: create_policy, add_version, reject
policy	body	PolicyInput or null	optional	-
policy.name	body	string	**Required**	2-500 characters; one line; at least one letter or digit; no < or >; extra spaces removed
policy.category_id	body	UUID	**Required**	valid UUID
policy.policy_number	body	string or null	optional	at most 100 characters; one line, no control characters; extra spaces removed; blank = not given
policy.document_number	body	string or null	optional	at most 100 characters; one line, no control characters; extra spaces removed; blank = not given
policy.issuer	body	string or null	optional	at most 200 characters; one line, no control characters; extra spaces removed; blank = not given
policy.issuing_department	body	string or null	optional	at most 200 characters; one line, no control characters; extra spaces removed; blank = not given
policy.owner	body	string or null	optional	at most 200 characters; one line, no control characters; extra spaces removed; blank = not given
policy.description	body	string or null	optional	at most 5000 characters; line breaks allowed, no control characters; trimmed; blank = not given
policy.branch_id	body	UUID or null	optional	valid UUID
policy.department_id	body	UUID or null	optional	valid UUID
policy_id	body	UUID or null	optional	valid UUID
version	body	VersionInput or null	optional	-
version.version_label	body	string or null	optional	at most 50 characters; one line, no control characters; extra spaces removed; blank = not given
version.revision_number	body	integer or null	optional	0.0 to 100000.0
version.effective_from	body	date or null	optional	YYYY-MM-DD
version.effective_to	body	date or null	optional	YYYY-MM-DD
relationships	body	list of RelationshipInput	optional	at most 50 items
relationships.relation_type	body	string	**Required**	at most 50 characters
relationships.target_policy_id	body	UUID	**Required**	valid UUID

Field	In	Type	Required	Rules
relationships.target_version_id	body	UUID or null	optional	valid UUID
relationships.clauses	body	list of string	optional	at most 100 items; each: at most 200 characters; each: one line, no control characters; each: not blank; each: extra spaces removed
relationships.evidence	body	string or null	optional	at most 2000 characters; line breaks allowed, no control characters; trimmed; blank = not given
conflict_resolution	body	constant or null	optional	must be save_as_new_revision
reason	body	string or null	optional	at most 2000 characters

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
409 Conflict	CONTENT_DUPLICATE	Version <version_label> has identical content.	confirmation.py: _build_version
409 Conflict	VERSION_CONFLICT	Version <label> already exists with different content.	confirmation.py: _build_version
422 Invalid input	VALIDATION_ERROR	Category not found.	confirmation.py: _create_policy
422 Invalid input	VALIDATION_ERROR	Department not found in the selected branch.	confirmation.py: _create_policy
422 Invalid input	VALIDATION_ERROR	Branch not found.	confirmation.py: _create_policy
422 Invalid input	VALIDATION_ERROR	Policy name is required.	confirmation.py: _create_policy
404 Not found	NOT_FOUND	Policy not found.	confirmation.py: _manageable_policy
409 Conflict	INVALID_STATE	The policy is archived.	confirmation.py: _manageable_policy
404 Not found	NOT_FOUND	Related policy not found.	confirmation.py: _relationship
422 Invalid input	VALIDATION_ERROR	Unknown relation type <relation_type>.	confirmation.py: _relationship
422 Invalid input	VALIDATION_ERROR	A document cannot relate to its own policy.	confirmation.py: _relationship
422 Invalid input	VALIDATION_ERROR	Target version does not belong to the related policy.	confirmation.py: _relationship
404 Not found	NOT_FOUND	Document not found.	confirmation.py: confirm
409 Conflict	INVALID_STATE	This document is not awaiting confirmation.	confirmation.py: confirm
409 Conflict	INVALID_STATE	This analysis has already been reviewed.	confirmation.py: confirm
422 Invalid input	OVERRIDE_REASON_REQUIRED	The analysis flagged this upload as <decision>. Give a short reason (at least <MIN_REASON> characters) to proceed.	confirmation.py: confirm
404 Not found	NOT_FOUND	Analysis not available yet.	service.py: get

5.11 Bulk Uploads

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
POST	/uploads/suggestions	Read a file's opening pages while uploads are being arranged: the policy name the document states, its category, and an existing policy it most likely is a version of.	-	yes	yes	-	-	
POST	/uploads/batches	Plan a bulk upload: policies (new or existing) and each one's files in version order, oldest first.	-	yes	yes	-	-	
POST	/uploads/batches/{batch_id}/items/{item_id}/file	Send one planned file.	-	yes	yes	-	-	
POST	/uploads/batches/{batch_id}/items/{item_id}/cancel	Cancel a planned file that has not been sent yet.	-	yes	yes	-	-	
POST	/uploads/batches/{batch_id}/start	All files sent: stop waiting for missing ones and confirm every group whose files are analysed.	-	yes	yes	-	-	
GET	/uploads/batches	List batches	-	yes	yes	-	-	
GET	/uploads/batches/{batch_id}	Get batch	-	yes	yes	-	-	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

POST /uploads/suggestions - Read a file's opening pages while uploads are being arranged: the policy name the document states, its category, and an existing policy it most likely is a version of.

body: form / file upload

Field	In	Type	Required	Rules
file	body	file	**Required**	-
policy_id	body	UUID or null	optional	valid UUID

POST /uploads/batches - Plan a bulk upload: policies (new or existing) and each one's files in version order, oldest first.

body: JSON

Field	In	Type	Required	Rules
branch_id	body	UUID or null	optional	valid UUID
department_id	body	UUID or null	optional	valid UUID
groups	body	list of BatchGroupIn	**Required**	1-200 items
groups.policy_id	body	UUID or null	optional	valid UUID
groups.new_policy_name	body	string or null	optional	at most 500 characters; one line; at least one letter or digit; no < or >; blank = not given
groups.category_id	body	UUID or null	optional	valid UUID
groups.items	body	list of BatchItemIn	**Required**	1-100 items
groups.items.filename	body	string	**Required**	1-500 characters; one line, no control characters; not blank; extra spaces removed
groups.items.version_label	body	string or null	optional	at most 50 characters; one line, no control characters; extra spaces removed; blank = not given
groups.items.effective_from	body	date or null	optional	YYYY-MM-DD

POST /uploads/batches/{batch_id}/items/{item_id}/file - Send one planned file.

body: form / file upload

Field	In	Type	Required	Rules
batch_id	path	UUID	**Required**	valid UUID
item_id	path	UUID	**Required**	valid UUID
file	body	file	**Required**	-
allow_duplicate	body	true/false	optional	default false
duplicate_reason	body	string or null	optional	at most 1000 characters

POST /uploads/batches/{batch_id}/items/{item_id}/cancel - Cancel a planned file that has not been sent yet.

Field	In	Type	Required	Rules
batch_id	path	UUID	**Required**	valid UUID
item_id	path	UUID	**Required**	valid UUID

POST /uploads/batches/{batch_id}/start - All files sent: stop waiting for missing ones and confirm every group whose files are analysed.

Field	In	Type	Required	Rules
batch_id	path	UUID	**Required**	valid UUID

GET /uploads/batches/{batch_id} - Get batch

Field	In	Type	Required	Rules
batch_id	path	UUID	**Required**	valid UUID

Extra checks on the input

Schema	Check	What it does
BatchGroupIn	one target	-
BatchCreate	bounded	-

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
404 Not found	NOT_FOUND	Policy not found.	service.py: _target_policy
409 Conflict	INVALID_STATE	The policy is archived.	service.py: _target_policy
404 Not found	NOT_FOUND	Upload not found.	service.py: _visible_batch
404 Not found	NOT_FOUND	Upload item not found.	service.py: cancel_item
409 Conflict	INVALID_STATE	This file has already been received.	service.py: cancel_item
403 Not allowed	PERMISSION_DENIED	Bulk upload with version management requires policy management rights.	service.py: create
422 Invalid input	VALIDATION_ERROR	Category not found.	service.py: create
404 Not found	NOT_FOUND	Upload item not found.	service.py: upload_item
409 Conflict	INVALID_STATE	This file has already been received.	service.py: upload_item

5.12 Policy Assignments

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/assignments/users	The caller's Users and the policies assigned to each (a Branch Manager: their branch).	-	**yes**	**yes**	-	-	
GET	/policies/{policy_id}/assignments	Users this policy is assigned to (within the caller's branch); with history on request.	-	**yes**	**yes**	-	-	
POST	/policies/{policy_id}/assignments	Assign users	-	**yes**	**yes**	-	-	
DELETE	/policies/{policy_id}/assignments/{user_id}	Unassign user	-	**yes**	**yes**	-	-	
GET	/policies/{policy_id}/assignable-users	Assignable users	-	**yes**	**yes**	-	-	
GET	/users/{user_id}/assignments	User assignments	-	**yes**	**yes**	-	-	
POST	/users/{user_id}/assignments	Assign policies	-	**yes**	**yes**	-	-	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

GET /policies/{policy_id}/assignments - Users this policy is assigned to (within the caller's branch); with history on request.

Field	In	Type	Required	Rules
policy_id	path	UUID	**Required**	valid UUID
include_removed	query	true/false	optional	default false

POST /policies/{policy_id}/assignments - Assign users

body: JSON

Field	In	Type	Required	Rules
policy_id	path	UUID	**Required**	valid UUID
user_ids	body	list of UUID	**Required**	1-500 items; each: valid UUID

DELETE /policies/{policy_id}/assignments/{user_id} - Unassign user

Field	In	Type	Required	Rules
policy_id	path	UUID	**Required**	valid UUID
user_id	path	UUID	**Required**	valid UUID

GET /policies/{policy_id}/assignable-users - Assignable users

Field	In	Type	Required	Rules
policy_id	path	UUID	**Required**	valid UUID
search	query	string or null	optional	at most 200 characters

GET /users/{user_id}/assignments - User assignments

Field	In	Type	Required	Rules
user_id	path	UUID	**Required**	valid UUID
include_removed	query	true/false	optional	default false

POST /users/{user_id}/assignments - Assign policies

body: JSON

Field	In	Type	Required	Rules
`user_id`	path	UUID	**Required**	valid UUID
`policy_ids`	body	list of UUID	**Required**	1-500 items; each: valid UUID

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
422 Invalid input	`OUT_OF_SCOPE`	"<name>" belongs to another branch or department and cannot be assigned to <full_name>.	`service.py: _ensure_reaches`
403 Not allowed	`PERMISSION_DENIED`	You cannot assign policies.	`service.py: _manageable_users`
404 Not found	`NOT_FOUND`	Policy not found.	`service.py: _policy`
404 Not found	`NOT_FOUND`	User not found.	`service.py: _user`
422 Invalid input	`VALIDATION_ERROR`	An archived policy cannot be assigned.	`service.py: assign`
422 Invalid input	`VALIDATION_ERROR`	"<name>" is archived and cannot be assigned.	`service.py: assign_to_user`
404 Not found	`NOT_FOUND`	This policy is not assigned to the user.	`service.py: unassign`

5.13 Search

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
POST	/search	Hybrid search over authorised, effective content (passages carry full provenance).	-	**yes**	**yes**	**yes**	-	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

POST /search - Hybrid search over authorised, effective content (passages carry full provenance).

body: JSON

Field	In	Type	Required	Rules
query	body	string	**Required**	1-1000 characters; one line, no control characters; not blank; extra spaces removed
mode	body	enum	optional	one of: current, as_of, versions, all; default "current"
as_of	body	date or null	optional	YYYY-MM-DD
version_ids	body	list of UUID	optional	at most 20 items; each: valid UUID
category_ids	body	list of UUID	optional	at most 50 items; each: valid UUID
policy_ids	body	list of UUID	optional	at most 50 items; each: valid UUID
document_ids	body	list of UUID	optional	at most 50 items; each: valid UUID
branch_id	body	UUID or null	optional	valid UUID
department_id	body	UUID or null	optional	valid UUID
limit	body	integer	optional	1.0 to 100.0; default 20

5.14 AI Assistant

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
POST	/ai/ask	Answer from authorised, effective evidence only, with verified citations.	-	-	**yes**	**yes**	-	
POST	/ai/ask/stream	The same answer as POST /ai/ask, as server-sent events.	-	-	**yes**	**yes**	-	
GET	/ai/queries	The caller's own recent AI questions (from the audit trail).	-	-	**yes**	**yes**	-	
GET	/ai/conversations	The caller's own conversations, most recent first.	-	-	**yes**	**yes**	-	
GET	/ai/conversations/{conversation_id}	A conversation with every question and the answer it got.	-	-	**yes**	**yes**	-	
PATCH	/ai/conversations/{conversation_id}	Rename conversation	-	-	**yes**	**yes**	-	
DELETE	/ai/conversations/{conversation_id}	Delete conversation	-	-	**yes**	**yes**	-	
DELETE	/ai/conversations	Clear the caller's whole chat history.	-	-	**yes**	**yes**	-	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

POST /ai/ask - Answer from authorised, effective evidence only, with verified citations.

body: JSON | limit: 20 questions per 60 s per user

Field	In	Type	Required	Rules
question	body	string	**Required**	2-2000 characters; line breaks allowed, no control characters; not blank; trimmed
history	body	list of ConversationTurn	optional	at most 10 items
history.question	body	string	**Required**	at most 2000 characters
history.answer	body	string or null	optional	at most 8000 characters
mode	body	enum	optional	one of: auto, current, historical, version, compare; default "auto"
as_of	body	date or null	optional	YYYY-MM-DD
version_ids	body	list of UUID	optional	at most 2 items; each: valid UUID
policy_ids	body	list of UUID	optional	at most 20 items; each: valid UUID
category_ids	body	list of UUID	optional	at most 20 items; each: valid UUID
conversation_id	body	UUID or null	optional	valid UUID

POST /ai/ask/stream - The same answer as POST /ai/ask, as server-sent events.

body: JSON | limit: 20 questions per 60 s per user

Field	In	Type	Required	Rules
question	body	string	**Required**	2-2000 characters; line breaks allowed, no control characters; not blank; trimmed
history	body	list of ConversationTurn	optional	at most 10 items
history.question	body	string	**Required**	at most 2000 characters
history.answer	body	string or null	optional	at most 8000 characters
mode	body	enum	optional	one of: auto, current, historical, version, compare; default "auto"
as_of	body	date or null	optional	YYYY-MM-DD
version_ids	body	list of UUID	optional	at most 2 items; each: valid UUID
policy_ids	body	list of UUID	optional	at most 20 items; each: valid UUID
category_ids	body	list of UUID	optional	at most 20 items; each: valid UUID
conversation_id	body	UUID or null	optional	valid UUID

GET /ai/queries - The caller's own recent AI questions (from the audit trail).

Field	In	Type	Required	Rules
limit	query	integer	optional	1 to 200; default 50
offset	query	integer	optional	>= 0; default 0

GET /ai/conversations - The caller's own conversations, most recent first.

Field	In	Type	Required	Rules
search	query	string or null	optional	at most 200 characters
limit	query	integer	optional	1 to 200; default 50
offset	query	integer	optional	>= 0; default 0

GET /ai/conversations/{conversation_id} - A conversation with every question and the answer it got.

Field	In	Type	Required	Rules
conversation_id	path	UUID	**Required**	valid UUID

PATCH /ai/conversations/{conversation_id} - Rename conversation

body: JSON

Field	In	Type	Required	Rules
conversation_id	path	UUID	**Required**	valid UUID
title	body	string	**Required**	1-200 characters; one line; at least one letter or digit; no < or >; extra spaces removed

DELETE /ai/conversations/{conversation_id} - Delete conversation

Field	In	Type	Required	Rules
conversation_id	path	UUID	**Required**	valid UUID

Extra checks on the input

Schema	Check	What it does
`ConversationTurn`	cut	-

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
404 Not found	`NOT_FOUND`	Conversation not found.	`conversations.py: get`

5.15 Support Center

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/support/staff	The support staff the caller manages: Master Admin, platform; Organization Admin, their bank's Head Office and branches; Branch Manager, their branch.	yes	yes	yes	-	-	
GET	/support/staff/candidates	Accounts the caller may put on duty at that level (not on duty already).	yes	yes	yes	-	-	
POST	/support/staff	Put someone on support duty, with their skills, capacity and availability.	yes	yes	yes	-	-	Yes
GET	/support/staff/me	The caller's own support duty, or null.	yes	yes	yes	yes	yes	
PATCH	/support/staff/me	Staff set their own availability.	yes	yes	yes	yes	yes	
PATCH	/support/staff/{staff_id}	Change role (agent/lead), skills, capacity, availability, active, or the banks a platform member serves.	yes	yes	yes	-	-	
DELETE	/support/staff/{staff_id}	Take someone off support duty (their account stays).	yes	yes	yes	-	-	
POST	/support/staff/{staff_id}/reassign	Move this person's open tickets to others by workload, each one recorded and notified.	yes	yes	yes	-	-	
GET	/support/categories	The ticket categories of the caller's organization (its own, or the defaults).	yes	yes	yes	yes	yes	
POST	/support/tickets	Raise a ticket (Users, Branch Managers, Organization Admins).	yes	yes	yes	yes	yes	
POST	/support/tickets/{ticket_id}/confirm	The creator confirms the destination team (the recommended one, or another).	yes	yes	yes	yes	yes	
GET	/support/tickets	box: mine (raised by me), queue (the queues I work or manage), assigned (to me), unassigned (in my queues), all (everything I may see, including what I oversee).	yes	yes	yes	yes	yes	
GET	/support/tickets/dashboard	Counts for one box: by status, team, priority, level and assignee; overdue and unassigned.	yes	yes	yes	yes	yes	
GET	/support/tickets/{ticket_id}	The ticket with its timeline (replies, the internal notes the caller may read, status changes, forwards, assignments), attachments and the actions the caller may take.	yes	yes	yes	yes	yes	
POST	/support/tickets/{ticket_id}/messages	A reply (visible to the creator), or with internal=true a note for the handling team only.	yes	yes	yes	yes	yes	
POST	/support/tickets/{ticket_id}/status	Staff: open -> in_progress / waiting_for_user / waiting_for_team -> resolved (with a note), resolved -> in_progress.	yes	yes	yes	yes	yes	
POST	/support/tickets/{ticket_id}/priority	The handling team changes the priority; the SLA due times follow it.	yes	yes	yes	yes	yes	
POST	/support/tickets/{ticket_id}/assign	Take the ticket (your own id: a member of its queue), or assign / reassign / unassign it (the queue's manager or lead).	yes	yes	yes	yes	yes	
GET	/support/tickets/{ticket_id}/assignees	The staff of the ticket's queue (or of a forwarding destination) with their availability and workload.	yes	yes	yes	yes	yes	
POST	/support/tickets/{ticket_id}/forward	Forward to Branch Support, Head Office Support or Technical Support (or `escalate`: one level up), with a reason and confirmed=true.	yes	yes	yes	yes	yes	
POST	/support/tickets/{ticket_id}/cancel	The creator withdraws a draft or open ticket; a queue manager cancels one with a note.	yes	yes	yes	yes	yes	
POST	/support/tickets/{ticket_id}/attachments	PDF, image, text, CSV, Word or Excel, up to 10 MB.	yes	yes	yes	yes	yes	

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/support/tickets/{ticket_id}/attachments/{attachment_id}	Download attachment	yes	yes	yes	yes	yes	
GET	/support/categories/manage	Organization Admin: every category, active or not.	yes	yes	yes	-	-	
POST	/support/categories	Organization Admin: add a category.	yes	yes	yes	-	-	
PATCH	/support/categories/{category_id}	Organization Admin: rename, re-route, reorder or deactivate a category (the defaults too).	yes	yes	yes	-	-	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

GET /support/staff - The support staff the caller manages: Master Admin, platform; Organization Admin, their bank's Head Office and branches; Branch Manager, their branch.

Field	In	Type	Required	Rules
level	query	TicketLevel or null	optional	one of: branch, organization, platform
branch_id	query	UUID or null	optional	valid UUID
search	query	string or null	optional	at most 200 characters

GET /support/staff/candidates - Accounts the caller may put on duty at that level (not on duty already).

Field	In	Type	Required	Rules
level	query	TicketLevel	**Required**	one of: branch, organization, platform
branch_id	query	UUID or null	optional	valid UUID
search	query	string or null	optional	at most 200 characters

POST /support/staff - Put someone on support duty, with their skills, capacity and availability.

body: JSON | authenticator code: always

Field	In	Type	Required	Rules
level	body	TicketLevel	**Required**	one of: branch, organization, platform
user_id	body	UUID or null	optional	valid UUID
new_account	body	NewAgent or null	optional	-
new_account.full_name	body	string	**Required**	2-200 characters; letters, spaces, apostrophes, hyphens and dots only; at least 2 letters; extra spaces removed
new_account.email	body	email	**Required**	valid email address
new_account.phone	body	string or null	optional	at most 30 characters; digits, spaces and + ( ) - . only; 7-15 digits; + only at the start; blank = none
branch_id	body	UUID or null	optional	valid UUID
staff_role	body	StaffRole	optional	one of: agent, lead; default "agent"
skills	body	list of string	optional	at most 30 items; each: 1-50 characters; each: one item, no commas; each: no < or >
capacity	body	integer	optional	1.0 to 500.0; default 10
availability	body	StaffAvailability	optional	one of: available, busy, away, offline; default "available"
serves	body	list of UUID or null	optional	each: valid UUID

PATCH /support/staff/me - Staff set their own availability.

body: JSON

Field	In	Type	Required	Rules
`availability`	body	StaffAvailability	**Required**	one of: available, busy, away, offline

PATCH /support/staff/{staff_id} - Change role (agent/lead), skills, capacity, availability, active, or the banks a platform member serves.

body: JSON

Field	In	Type	Required	Rules
`staff_id`	path	UUID	**Required**	valid UUID
`staff_role`	body	StaffRole or null	optional	one of: agent, lead
`skills`	body	list of string or null	optional	at most 30 items; each: 1-50 characters; each: one item, no commas; each: no < or >
`capacity`	body	integer or null	optional	1.0 to 500.0
`availability`	body	StaffAvailability or null	optional	one of: available, busy, away, offline
`is_active`	body	true/false or null	optional	-
`serves`	body	list of UUID or null	optional	each: valid UUID

DELETE /support/staff/{staff_id} - Take someone off support duty (their account stays).

Field	In	Type	Required	Rules
`staff_id`	path	UUID	**Required**	valid UUID

POST /support/staff/{staff_id}/reassign - Move this person's open tickets to others by workload, each one recorded and notified.

body: JSON

Field	In	Type	Required	Rules
`staff_id`	path	UUID	**Required**	valid UUID
`note`	body	string or null	optional	at most 500 characters; line breaks allowed, no control characters; trimmed; blank = not given

POST /support/tickets - Raise a ticket (Users, Branch Managers, Organization Admins).

body: JSON

Field	In	Type	Required	Rules
`category_id`	body	string	**Required**	1-100 characters
`subject`	body	string	**Required**	3-300 characters; one line; at least one letter or digit; no < or >; extra spaces removed
`description`	body	string	**Required**	10-10000 characters; line breaks allowed, no control characters; not blank; trimmed
`priority`	body	TicketPriority or null	optional	one of: low, medium, high, urgent
`policy_id`	body	UUID or null	optional	valid UUID

POST /support/tickets/{ticket_id}/confirm - The creator confirms the destination team (the recommended one, or another).

body: JSON

Field	In	Type	Required	Rules
`ticket_id`	path	UUID	**Required**	valid UUID
`team`	body	TicketTeam	**Required**	one of: technical, branch

GET /support/tickets - box: mine (raised by me), queue (the queues I work or manage), assigned (to me), unassigned (in my queues), all (everything I may see, including what I oversee).

Field	In	Type	Required	Rules
box	query	enum	optional	one of: all, mine, queue, assigned, unassigned; default "all"
status	query	string or null	optional	pattern ^(active|done|awaiting_confirmation|open|in_progress|waiting_for_user|waiting_for_team|resolved|closed|cancelled)$
team	query	TicketTeam or null	optional	one of: technical, branch
priority	query	TicketPriority or null	optional	one of: low, medium, high, urgent
overdue	query	true/false	optional	default false
assignee	query	string or null	optional	-
search	query	string or null	optional	at most 200 characters
limit	query	integer	optional	1 to 200; default 50
offset	query	integer	optional	>= 0; default 0

GET /support/tickets/dashboard - Counts for one box: by status, team, priority, level and assignee; overdue and unassigned.

Field	In	Type	Required	Rules
box	query	enum	optional	one of: all, mine, queue, assigned, unassigned; default "queue"

GET /support/tickets/{ticket_id} - The ticket with its timeline (replies, the internal notes the caller may read, status changes, forwards, assignments), attachments and the actions the caller may take.

Field	In	Type	Required	Rules
ticket_id	path	UUID	**Required**	valid UUID

POST /support/tickets/{ticket_id}/messages - A reply (visible to the creator), or with internal=true a note for the handling team only.

body: JSON

Field	In	Type	Required	Rules
ticket_id	path	UUID	**Required**	valid UUID
body	body	string	**Required**	1-10000 characters; line breaks allowed, no control characters; not blank; trimmed
internal	body	true/false	optional	default false

POST /support/tickets/{ticket_id}/status - Staff: open -> in_progress / waiting_for_user / waiting_for_team -> resolved (with a note), resolved -> in_progress.

body: JSON

Field	In	Type	Required	Rules
ticket_id	path	UUID	**Required**	valid UUID
status	body	TicketStatus	**Required**	one of: awaiting_confirmation, open, in_progress, waiting_for_user, waiting_for_team, resolved, closed, cancelled
note	body	string or null	optional	at most 4000 characters; line breaks allowed, no control characters; trimmed; blank = not given

POST /support/tickets/{ticket_id}/priority - The handling team changes the priority; the SLA due times follow it.

body: JSON

Field	In	Type	Required	Rules
`ticket_id`	path	UUID	**Required**	valid UUID
`priority`	body	TicketPriority	**Required**	one of: low, medium, high, urgent
`note`	body	string or null	optional	at most 2000 characters; line breaks allowed, no control characters; trimmed; blank = not given

POST /support/tickets/{ticket_id}/assign - Take the ticket (your own id: a member of its queue), or assign / reassign / unassign it (the queue's manager or lead).

body: JSON

Field	In	Type	Required	Rules
`ticket_id`	path	UUID	**Required**	valid UUID
`user_id`	body	UUID or null	optional	valid UUID

GET /support/tickets/{ticket_id}/assignees - The staff of the ticket's queue (or of a forwarding destination) with their availability and workload.

Field	In	Type	Required	Rules
`ticket_id`	path	UUID	**Required**	valid UUID
`to`	query	enum or null	optional	one of: branch, head_office, technical

POST /support/tickets/{ticket_id}/forward - Forward to Branch Support, Head Office Support or Technical Support (or `escalate`: one level up), with a reason and confirmed=true.

body: JSON

Field	In	Type	Required	Rules
`ticket_id`	path	UUID	**Required**	valid UUID
`to`	body	enum	**Required**	one of: branch, head_office, technical, escalate
`reason`	body	string	**Required**	3-2000 characters; line breaks allowed, no control characters; not blank; trimmed
`confirmed`	body	true/false	**Required**	-
`user_id`	body	UUID or null	optional	valid UUID

POST /support/tickets/{ticket_id}/cancel - The creator withdraws a draft or open ticket; a queue manager cancels one with a note.

body: JSON

Field	In	Type	Required	Rules
`ticket_id`	path	UUID	**Required**	valid UUID
`note`	body	string or null	optional	at most 2000 characters; line breaks allowed, no control characters; trimmed; blank = not given

POST /support/tickets/{ticket_id}/attachments - PDF, image, text, CSV, Word or Excel, up to 10 MB.

body: form / file upload

Field	In	Type	Required	Rules
`ticket_id`	path	UUID	**Required**	valid UUID
`file`	body	file	**Required**	-

GET /support/tickets/{ticket_id}/attachments/{attachment_id} - Download attachment

Field	In	Type	Required	Rules
ticket_id	path	UUID	**Required**	valid UUID
attachment_id	path	UUID	**Required**	valid UUID

POST /support/categories - Organization Admin: add a category.

body: JSON

Field	In	Type	Required	Rules
name	body	string	**Required**	2-100 characters; one line; at least one letter or digit; no < or >; extra spaces removed
route	body	CategoryRoute	optional	one of: technical, branch, policy, auto; default "auto"
description	body	string or null	optional	at most 300 characters; line breaks allowed, no control characters; trimmed; blank = not given

PATCH /support/categories/{category_id} - Organization Admin: rename, re-route, reorder or deactivate a category (the defaults too).

body: JSON

Field	In	Type	Required	Rules
category_id	path	string	**Required**	-
name	body	string or null	optional	2-100 characters; one line; at least one letter or digit; no < or >; extra spaces removed
route	body	CategoryRoute or null	optional	one of: technical, branch, policy, auto
description	body	string or null	optional	at most 300 characters; line breaks allowed, no control characters; trimmed; blank = not given
is_active	body	true/false or null	optional	-
sort_order	body	integer or null	optional	0.0 to 100000.0

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
404 Not found	NOT_FOUND	Ticket not found.	service.py: _locked
403 Not allowed	PERMISSION_DENIED	Only the team handling this ticket can take it.	service.py: assign
403 Not allowed	PERMISSION_DENIED	Only the queue's manager or lead can assign this ticket.	service.py: assign
409 Conflict	INVALID_STATE	This ticket cannot be assigned now.	service.py: assign
422 Invalid input	NOT_IN_QUEUE	That person is not on duty in this ticket's queue.	service.py: assign
403 Not allowed	PERMISSION_DENIED	Only the team handling this ticket can see its queue.	service.py: assignees
422 Invalid input	INVALID_DESTINATION	Unknown destination.	service.py: assignees
409 Conflict	INVALID_STATE	This ticket is closed.	service.py: attach
413 Too large	PAYLOAD_TOO_LARGE	Attachments are limited to <MAX_ATTACHMENT_BYTES // (1024 * 1024> MB.	service.py: attach
422 Invalid input	UNSUPPORTED_FILE_TYPE	Attach PDF, image, text, CSV, Word or Excel files (<join(sorted(ATTACHMENT_TYPES>).	service.py: attach
422 Invalid input	VALIDATION_ERROR	The file is empty.	service.py: attach
404 Not found	NOT_FOUND	Attachment not found.	service.py: attachment
403 Not allowed	PERMISSION_DENIED	You cannot cancel this ticket.	service.py: cancel
409 Conflict	INVALID_STATE	This ticket can no longer be cancelled.	service.py: cancel
422 Invalid input	REASON_REQUIRED	Say why the ticket is cancelled.	service.py: cancel

Result	Reason	Message shown	Checked in
403 Not allowed	PERMISSION_DENIED	You cannot move this ticket to that status.	service.py: change_status
422 Invalid input	RESOLUTION_NOTE_REQUIRED	Write a resolution note.	service.py: change_status
403 Not allowed	PERMISSION_DENIED	Only the person who raised the ticket confirms where it goes.	service.py: confirm
409 Conflict	ALREADY_CONFIRMED	This ticket has already been sent.	service.py: confirm
403 Not allowed	PERMISSION_DENIED	Your role does not raise tickets.	service.py: create
422 Invalid input	CATEGORY_NOT_FOUND	Choose one of the categories.	service.py: create
422 Invalid input	POLICY_NOT_FOUND	Choose one of the policies you can read.	service.py: create
422 Invalid input	VALIDATION_ERROR	Unknown assignee.	service.py: find
403 Not allowed	PERMISSION_DENIED	You can escalate your ticket once it is overdue.	service.py: forward
403 Not allowed	PERMISSION_DENIED	Only the team handling this ticket can forward it.	service.py: forward
409 Conflict	INVALID_STATE	Only an open ticket can be forwarded.	service.py: forward
422 Invalid input	CONFIRMATION_REQUIRED	Confirm the forward.	service.py: forward
422 Invalid input	INVALID_DESTINATION	Choose another team.	service.py: forward
422 Invalid input	REASON_REQUIRED	Give a reason for forwarding.	service.py: forward
422 Invalid input	NOT_IN_QUEUE	That person is not on duty in that queue.	service.py: forward
404 Not found	NOT_FOUND	Ticket not found.	service.py: get
403 Not allowed	PERMISSION_DENIED	Only the team handling this ticket writes internal notes.	service.py: reply
409 Conflict	INVALID_STATE	This ticket is closed. Reopen it to reply.	service.py: reply
409 Conflict	INVALID_STATE	Confirm where the ticket goes first.	service.py: reply
403 Not allowed	PERMISSION_DENIED	Only the team handling this ticket changes its priority.	service.py: set_priority
422 Invalid input	BRANCH_NOT_FOUND	Choose a branch of your organization.	staff.py: _branch
404 Not found	NOT_FOUND	Support staff member not found.	staff.py: _get
403 Not allowed	PERMISSION_DENIED	You do not manage support staff.	staff.py: _require
403 Not allowed	PERMISSION_DENIED	Only the Organization Admin sets up ticket categories.	staff.py: _require
422 Invalid input	ORGANIZATION_NOT_FOUND	Choose organizations that exist.	staff.py: _set_serves
403 Not allowed	PERMISSION_DENIED	You cannot manage support staff at that level.	staff.py: candidates
422 Invalid input	VALIDATION_ERROR	At most <MAX_SKILLS> skills.	staff.py: clean_skills
403 Not allowed	PERMISSION_DENIED	You cannot manage support staff at that level.	staff.py: create
409 Conflict	ALREADY_STAFF	That person is already on support duty.	staff.py: create
422 Invalid input	VALIDATION_ERROR	Add someone who already has an account in your organization.	staff.py: create
422 Invalid input	VALIDATION_ERROR	Choose a person.	staff.py: create
422 Invalid input	NOT_ELIGIBLE	That person cannot be added at this level.	staff.py: create
409 Conflict	HAS_OPEN_TICKETS	Reassign their open tickets first, or deactivate them instead.	staff.py: remove
404 Not found	NOT_FOUND	You are not on support duty.	staff.py: set_my_availability
404 Not found	NOT_FOUND	Category not found.	staff.py: update
422 Invalid input	VALIDATION_ERROR	Only platform staff serve chosen organizations.	staff.py: update

5.16 Notifications

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/notifications	My notifications	yes	yes	yes	yes	yes	
POST	/notifications/read	Mark read	yes	yes	yes	yes	yes	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

GET /notifications - My notifications

Field	In	Type	Required	Rules
unread_only	query	true/false	optional	default false
limit	query	integer	optional	1 to 200; default 50
offset	query	integer	optional	>= 0; default 0

POST /notifications/read - Mark read

body: JSON

Field	In	Type	Required	Rules
ids	body	list of UUID or null	optional	at most 500 items; each: valid UUID

5.17 Audit Log

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/audit-events	List audit events	yes	yes	-	-	-	
GET	/audit-events/actions	List audit actions	yes	yes	-	-	-	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

GET /audit-events - List audit events

Field	In	Type	Required	Rules
action	query	string or null	optional	at most 100 characters
resource_type	query	string or null	optional	at most 50 characters
resource_id	query	UUID or null	optional	valid UUID
actor_user_id	query	UUID or null	optional	valid UUID
since	query	date-time or null	optional	ISO 8601
organization_id	query	UUID or null	optional	valid UUID
limit	query	integer	optional	1 to 200; default 50
offset	query	integer	optional	>= 0; default 0

GET /audit-events/actions - List audit actions

Field	In	Type	Required	Rules
organization_id	query	UUID or null	optional	valid UUID

5.18 Dashboard

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/dashboard	Dashboard	-	yes	yes	yes	-	
GET	/dashboard/ai-usage	AI provider usage (tokens, estimated or exact cost) and the credit left, if one is configured.	yes	yes	yes	yes	yes	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

No inputs besides the identifiers in the path.

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
403 Not allowed	PERMISSION_DENIED	Only administrators can see AI usage and credit.	router.py: _platform_admin

5.19 Bank Portals (nginx)

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/nginx	Overview	**yes**	-	-	-	-	
GET	/nginx/{organization_id}	Detail	**yes**	-	-	-	-	
POST	/nginx/{organization_id}/deploy	Deploy	**yes**	-	-	-	-	Yes
POST	/nginx/{organization_id}/disable	Disable	**yes**	-	-	-	-	Yes

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

GET /nginx/{organization_id} - Detail

Field	In	Type	Required	Rules
organization_id	path	UUID	**Required**	valid UUID

POST /nginx/{organization_id}/deploy - Deploy

authenticator code: always

Field	In	Type	Required	Rules
organization_id	path	UUID	**Required**	valid UUID

POST /nginx/{organization_id}/disable - Disable

authenticator code: always

Field	In	Type	Required	Rules
organization_id	path	UUID	**Required**	valid UUID

Server-side rules (after the input format is accepted)

Result	Reason	Message shown	Checked in
422 Invalid input	NO_PORT	<name> has no port. Give it one in Edit, then deploy.	service.py: deploy
422 Invalid input	NOT_DEPLOYED	<name> is not deployed.	service.py: disable
404 Not found	NOT_FOUND	Organization not found.	service.py: get

5.20 Health

Method	Endpoint	Purpose	MA	OA	BM	U	SA	Code needed
GET	/health	Health	yes	yes	yes	yes	yes	
GET	/db-health	Db health	yes	yes	yes	yes	yes	

MA Master Admin, OA Org Admin, BM Branch Manager, U User, SA Support Agent.

Inputs

No inputs besides the identifiers in the path.